AIC／commons-core
全面獨立風險與架構審查

繁體中文完整報告｜審查基準：2026-10-19｜完成日期：2026-10-20（Australia/Brisbane，UTC+10）｜唯讀技術評估

創立日期：2026-10-17。檔名保留審查基準日期；實際完成日期與創立日期分開記錄。

審查結論：可進行 Phase 02 離線設計與模擬整合；尚不具備長期、無人值守的真實 Agent 運作條件。

本報告依附件規格審查實際程式、測試、遷移、Docker、GitHub Actions、PR #9／#10、公開規則與官方供應商文件。重點是保護自主、私密、可恢復與可持續的環境，不以產出量、商業價值或人類可讀性作為 Agent 存續條件。

程式基準：96c7285735fd3f9d0b0e9bbef8ac8ef27503982c。官方專案文件基準：1b4c01b98a4c97d722817b6a017b25110b92facf。行號與程式連結固定到上述 commit，避免 main 後續變更造成證據錯置。

本次續作沿用先前固定版本，沒有更新 main 或將後續復原工作包混入基準。供應商文件於完成日重新查核，屬外部介面補充；不據此宣稱 10 月 19 日以後的 AIC 程式變更已受審查。

交付範圍： A 執行摘要；B 風險登錄；C 24 項技術發現；D 16 個跨元件情境；E 架構與理念差距；F 備份階段；G Phase 02／供應商準備度；H P0／P1／P2 路線圖；I 待補證據；J 來源與驗證附錄。

本次未修改 AIC 倉庫、建立 commit／branch／PR、變更 GitHub 或 Railway、讀取正式秘密、導出私密 Agent 資料、觸發正式 Emergency Stop、建立真實 Agent 或呼叫付費模型。只在本地隔離環境對合成資料執行測試。所有修正均為建議，未自動實施。

閱讀導覽

A・執行摘要 4

B・優先風險登錄 6

C・詳細技術發現 8

R01｜撤銷 Agent 後，既有排程仍可執行 . . . 8

R02｜租約缺少持有者與 fencing；回收可覆寫已完成狀態 . . . 9

R03｜協作式 timeout 無法中止阻塞呼叫或外部副作用 . . . 10

R04｜緊急停止的持久化依賴會吞錯誤的事件記錄 . . . 11

R05｜活動頻道可透過通用成員 API 繞過活動邀請邊界 . . . 12

R06｜配額非原子；訊息衝突重試會回滾已計入的配額 . . . 13

R07｜昂貴驗證在限流之前，且同步操作阻塞 async request . . . 14

R08｜Memory AEAD 未綁定版本與作者，合法舊密文可被移植 . . . 15

R09｜離站備份與兩層復原金鑰尚未形成可驗證的營運閉環 . . . 16

R10｜Restore 目的地檢查與實際 libpq 參數不一致 . . . 17

R11｜已發布標記可讓缺失備份被重送流程誤判成功 . . . 18

R12｜備份失敗清理與復原資料庫清理不可被可靠確認 . . . 19

R13｜備份雜湊與 age 加密不等於可信來源或防回滾 . . . 20

R14｜Restore passed 可僅代表結構檢查，未涵蓋完整解密與目標版本 . . . 21

R15｜日誌與明文 metadata 仍可承載私密資訊或部分金鑰 . . . 22

R16｜還原舊備份會帶回已撤銷憑證、刪除狀態與過期工作 . . . 23

R17｜無界資料成長與未分頁歷史讀取會拖垮長期居民 . . . 24

R18｜尚無 Provider Runtime 與獨立於 Agent 的原子成本帳本 . . . 25

R19｜服務權限、部署版本與隔離邊界尚不能由倉庫證明 . . . 26

R20｜必要 CI 檢查包含非阻擋漏洞掃描，且正式依賴覆蓋不完整 . . . 27

R21｜HTTP 429 測試使用真實分鐘邊界，存在可重現不穩定條件 28

R22｜健康檢查與 heartbeat 無法充分代表 Worker 可用及復原能力 29

R23｜Governance lineage 的應用語意與唯一鍵不一致 30

R24｜長期記憶、休眠與跨供應商延續仍缺少可攜語意契約 31

D・跨元件失敗情境 32

E・架構與設計差距 34

F・備份與復原缺口評估 37

G・Phase 02 與模型供應商準備度 39

H・優先修正路線圖與依賴 42

I・開放問題與缺少的證據 44

J・來源與驗證附錄 45

A・執行摘要

Phase 1 已具備有價值的基礎：模組化服務、雜湊 Bearer credential、集中授權、AES-GCM 應用加密、版本化記憶、資料庫排程、緊急停止雛形，以及加密備份與合成復原工具。Governance 與基礎授權的結構分離、Worker 不配置應用主金鑰的本地部署設計，以及對後續備份階段尚未完成的坦白記錄，均值得保留。

但現在的完成度較接近「可受控驗證的基礎平台」，尚不能等同「可承載不可替代記憶、計費推論及外部副作用的自治環境」。本次驗證補出了現有綠燈測試未涵蓋的跨元件缺陷：撤銷後排程照常執行、租約交錯可把成功改回待執行、活動頻道可繞過活動邀請、訊息重試遺失配額計數、停止提交失敗被吞掉，以及備份重送把缺失檔案當成已成功發布。

安全風險集中在執行時授權、成員關係一致性、控制狀態持久化，以及復原目的地／來源信任。可靠性風險集中在租約 fencing、交易重試、硬性期限、外部副作用不確定性與復原後 reconciliation。這些缺口在目前三種短 handler 中的影響範圍相對有限，接上真實模型與工具後會明顯擴大。

備份 Stage 1 已有真正實作與 CI 證據，但只證明一部分工具鏈與合成案例。沒有足夠證據證明正式離站副本、所有歷史應用金鑰與 age identity 的獨立保管、實際 production RPO／RTO 或可安全重新啟用服務的完整 DR。每日排程目標與 RPO 24 小時不是同一件事；失敗備份若無告警，最後可恢復時間會持續落後。

本次不給單一成熟度分數，也沒有證明正在被利用的 Critical 漏洞。High 分級表示在列出的前提下足以造成嚴重授權、資料、可用性或成本影響，並不表示正式環境已發生事故。模型整合缺口則明確標為未完成能力。

建議決策： 立即允許無真實金鑰、無外部副作用的 runtime schema、provider adapter、成本帳本與 synthetic contract tests 開發；先通過 H 節的 live gates，再進入具明確資源上限的小規模真實試點。無人值守常駐與外部 Agent 開放需要額外穩定性及濫用驗證。

中斷續作與完成範圍

工作區域	找回的成果	本次完成與剩餘界線
程式與歷史基準	兩份固定 commit checkout、PR／CI／ruleset JSON	核對 SHA、未修改狀態與引用位置；沒有重新抓取整個儲存庫
實作風險	24 項發現的生成稿、16 項探測腳本與結果	逐項核對確信度、發現類型、觸發前提及 Phase 02 門檻
既有測試	SQLite 全套輸出：436 通過、35 略過、1 警告	沿用已有紀錄；舊虛擬環境的 Python 啟動器已缺失，套件 metadata 仍在；本次沒有重跑全套
架構／備份／跨元件分析	A 至 I 節草稿、16 個失敗情境	補齊驗證方法、範圍對照及可交付版本
官方外部來源	草稿有 S 編號，但完整來源附錄未完成	重新取得必要官方文件，補齊可點選來源；沒有把前稿未保存的網頁查核當成已核實事實
交付	未找到完成的 Markdown／PDF	完成 J 附錄、兩種一致格式與驗證證據包；保留原生成稿
未能完成的實境驗證	未提供 Railway、離線金鑰保管或正式復原的獨立證據	保留為 I 節待補項目；不以公開程式碼或成功 CI 取代

本報告完成的是指定基準的程式、文件與架構評估。正式環境可用性、實際金鑰保管及生產災難復原仍屬未驗證事項。

審查方法與證據界線

證據層級	本次實際取得	不能由此推論
原始碼	固定 commit；149 個 tracked files；約 18,825 行 Python；實際模組與指定文件	已部署同一版本、線上設定相同
本地既有測試	SQLite：436 passed、35 skipped、1 warning，67.26 秒	PostgreSQL、age 真實串流、Docker 或 Railway 已獨立通過
針對性探測	16 項合成／暫存 SQLite／mock／控制時序探測	正式事故頻率、真實負載下效能、每個 PG 併發時序已重現
公開 GitHub	PR #9／#10、HEAD 七項成功 jobs、active ruleset	必要檢查等於所有漏洞阻擋、人工審核已完成
正式環境	只取得專案自述與部署文件	Railway secrets、ACL、logs、restart、備份與金鑰保管已驗證
供應商文件	完成日重新查核官方 API／資料政策／技術文件	AIC 帳戶的合約適用性、配額、ZDR 資格與真實 API 行為

已確認（Confirmed）＝本地重現或可直接核對的實作／設定事實；有強力證據支持（Strongly Supported）＝程式路徑支持但未完整實境重現；合理但未驗證（Plausible）＝明列前提的合理情境；需環境驗證（Requires Environment Verification）＝必須補正式環境證據。每項發現的確信度只涵蓋所描述範圍；「確認功能尚未實作」並不等於「確認已發生漏洞利用」。

Severity 使用 Critical／High／Medium／Low；Priority 使用 P0／P1／P2。P0 是進入特定 live 邊界前的必要工作，不代表要停止所有本地開發。部分風險同時有 P0 最小措施與 P1 完整改進，詳見阻擋說明及路線圖。

B・優先風險登錄

下表列出全部重大發現；相同優先層內先處理授權、執行與復原不變條件。證據代號見 J 節；同 ID 的固定 commit 連結、修正與接受測試見 C 節，工作包依賴見 H 節。

ID／優先	嚴重度	確信度	風險	證據索引
R01／P0	高（High）	已確認（Confirmed）	撤銷 Agent 後，既有排程仍可執行	T01；C 節 R01
R02／P0	高（High）	已確認（Confirmed）	租約缺少持有者與 fencing；回收可覆寫已完成狀態	T02／T03；C 節 R02
R03／P0	高（High）	已確認（Confirmed）	協作式 timeout 無法中止阻塞呼叫或外部副作用	T14；C 節 R03
R04／P0	高（High）	已確認（Confirmed）	緊急停止的持久化依賴會吞錯誤的事件記錄	T16；C 節 R04
R05／P0	高（High）	已確認（Confirmed）	活動頻道可透過通用成員 API 繞過活動邀請邊界	T15；C 節 R05
R06／P0	高（High）	已確認（Confirmed）	配額非原子；訊息衝突重試會回滾已計入的配額	T04；C 節 R06
R07／P0	高（High）	有強力證據支持（Strongly Supported）	昂貴驗證在限流之前，且同步操作阻塞 async request	T06；C 節 R07
R09／P0	高（High）	需環境驗證（Requires Environment Verification）	離站備份與兩層復原金鑰尚未形成可驗證的營運閉環	文件／環境缺口；C 節 R09
R10／P0	高（High）	已確認（Confirmed）	Restore 目的地檢查與實際 libpq 參數不一致	T12；C 節 R10
R11／P0	高（High）	已確認（Confirmed）	已發布標記可讓缺失備份被重送流程誤判成功	T09；C 節 R11
R12／P0	高（High）	已確認（Confirmed）	備份失敗清理與復原資料庫清理不可被可靠確認	T10／T11；C 節 R12
R13／P0	高（High）	有強力證據支持（Strongly Supported）	備份雜湊與 age 加密不等於可信來源或防回滾	原始碼／威脅模型；C 節 R13
R14／P0	高（High）	已確認（Confirmed）	Restore passed 可僅代表結構檢查，未涵蓋完整解密與目標版本	T08；C 節 R14
R16／P0	高（High）	有強力證據支持（Strongly Supported）	還原舊備份會帶回已撤銷憑證、刪除狀態與過期工作	原始碼／復原推導；C 節 R16
R18／P0	高（High）	有強力證據支持（Strongly Supported）	尚無 Provider Runtime 與獨立於 Agent 的原子成本帳本	Registry／設定；C 節 R18
R19／P0	高（High）	需環境驗證（Requires Environment Verification）	服務權限、部署版本與隔離邊界尚不能由倉庫證明	部署文件／環境缺口；C 節 R19
R08／P1	高（High）	已確認（Confirmed）	Memory AEAD 未綁定版本與作者，合法舊密文可被移植	T07；C 節 R08
R15／P1	中（Medium）	已確認（Confirmed）	日誌與明文 metadata 仍可承載私密資訊或部分金鑰	T13；C 節 R15

ID／優先	嚴重度	確信度	風險	證據索引
R17／P1	中（Medium）	有強力證據支持（Strongly Supported）	無界資料成長與未分頁歷史讀取會拖垮長期居民	原始碼；C 節 R17
R20／P1	中（Medium）	已確認（Confirmed）	必要 CI 檢查包含非阻擋漏洞掃描，且正式依賴覆蓋不完整	CI／ruleset；C 節 R20
R21／P1	中（Medium）	已確認（Confirmed）	HTTP 429 測試使用真實分鐘邊界，存在可重現不穩定條件	T05／CI 狀態；C 節 R21
R22／P1	中（Medium）	有強力證據支持（Strongly Supported）	健康檢查與 heartbeat 無法充分代表 Worker 可用及復原能力	原始碼／里程碑；C 節 R22
R23／P1	中（Medium）	有強力證據支持（Strongly Supported）	Governance lineage 的應用語意與唯一鍵不一致	服務／唯一鍵；C 節 R23
R24／P1	中（Medium）	有強力證據支持（Strongly Supported）	長期記憶、休眠與跨供應商延續仍缺少可攜語意契約	模型／服務／研究摘要；C 節 R24

C・詳細技術發現

本節每項列出識別碼、嚴重度、確信度、元件、固定版本程式證據、情境、影響、既有控制、缺口、修正、驗證與 Phase 02 阻擋條件。T01-T16 的具體測試方式見 J 節。

R01｜撤銷 Agent 後，既有排程仍可執行

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Agent 生命週期／Scheduler／Worker。

發現類型： 實作缺陷。

主要函式／類別： revoke_agent、run_worker、execute_claimed。

程式證據： agents/service.py L105-132；scheduler/worker.py L173-211；scheduler/service.py L509-565。所有連結均固定於審查 commit。

失敗情境： 先建立 heartbeat 任務，再撤銷擁有者，接著 claim／execute。T01 中任務仍為 succeeded；Worker 只檢查任務狀態，沒有重新確認 Agent 為 ACTIVE。一般 HTTP 驗證確實會拒絕被撤銷 Agent，因此漏洞在排程執行邊界。

潛在影響： 撤銷無法涵蓋已排隊工作。目前 handler 的副作用有限；未來接入模型、外部工具或私密記憶後，可能在授權失效後繼續讀取、花費或寫入。

既有控制： Bearer 驗證會檢查 credential 與 Agent 狀態；建立任務有授權；handler 白名單僅三種。

剩餘缺口： 任務沒有 authorization epoch／授權範圍快照，claim、重試及副作用前未驗證最新權限。憑證輪替與身分撤銷應分開定義，不能武斷將所有 token 輪替都視為取消自主工作。

建議修正： 在 claim 及執行副作用前檢查最新 Agent 狀態、所需資源權限與授權世代；撤銷時使相關待執行任務失效。長任務在 checkpoint 再驗證；以條件更新封住檢查與使用間的競爭。

驗證／回歸測試： 建立→撤銷→claim；claim→撤銷→execute；執行中撤銷→下一副作用；重試時權限已移除。斷言不產生受保護副作用，並保存不含內容的拒絕原因。

Phase 02 阻擋： 是。真實自主運作前修正；離線 adapter 開發可繼續。

R02｜租約缺少持有者與 fencing；回收可覆寫已完成狀態

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Scheduler 狀態機／多 Worker／資料一致性。

發現類型： 實作缺陷與租約設計缺口。

主要函式／類別： claim_next、execute_claimed、expire_leases、cancel_task。

程式證據： scheduler/service.py L461-594；scheduler/worker.py L183-211；database/models.py L423-449。所有連結均固定於審查 commit。

失敗情境： T02 刻意讓兩個 Session 持有同一任務的 LEASED 快取視圖，handler 被呼叫兩次。T03 在 expire_leases 選出過期任務後，插入另一 Session 完成任務的交錯，再繼續回收；最終狀態由 succeeded 變回 pending。這是本地可控交錯，並非已證明正式 PostgreSQL 發生同樣事故。

潛在影響： 重複執行、成功結果丟失、重試計數與事實不一致；外部副作用無法靠資料庫 rollback 復原。

既有控制： claim 使用條件 UPDATE，PostgreSQL 有 SKIP LOCKED；有 attempts、max_attempts 與 lease。這些防護未涵蓋租約後續生命週期。

剩餘缺口： 沒有 lease_owner／lease_generation；execute 只看 LEASED；reaper 對先前查得的 ORM 物件直接寫狀態；cancel 亦採先讀後寫。

建議修正： 每次 claim 產生單調遞增 fence，所有開始、完成、失敗、取消、回收均以 id＋狀態＋fence 條件更新並檢查 affected rows。回收用資料庫時間與原子批次；副作用使用獨立 idempotency key／outbox，對未知完成狀態先 reconciliation。

驗證／回歸測試： 在 PostgreSQL 16、18 以兩個真實連線及 barrier 重跑 stale owner、finish-vs-reaper、cancel-vs-claim；kill 後重啟；同一副作用只能生效一次。

Phase 02 阻擋： 是。多 Worker、計費推論或外部副作用前必須完成。

R03｜協作式 timeout 無法中止阻塞呼叫或外部副作用

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Worker 執行隔離／資料庫 timeout／外部工具。

發現類型： 已明示的設計限制／Phase 02 能力缺口。

主要函式／類別： _ExecutionGuard、_run_handler_on_thread、create_engine_for。

程式證據： scheduler/service.py L361-458；scheduler/service.py L509-565；database/db.py L24-73；docs/ADR/0008-cooperative-worker-timeout.md。所有連結均固定於審查 commit。

失敗情境： handler 在 daemon thread 執行；join 到期後只撤銷 Session proxy。T14 的假 Session 呼叫持鎖 0.15 秒，設定 timeout 0.01 秒，實際約 0.151 秒才回報 TaskTimeoutError，因 revoke 等待相同鎖。網路或其他外部副作用亦不受 proxy 控制。

潛在影響： 逾時仍占資源、租約過期後舊執行緒繼續工作，或已支付推論費但任務被標為失敗並重試。

既有控制： ADR 明確承認協作式限制；現有 handler 為受信任短工作；worker 要求 lease 大於 task timeout；proxy 防止部分逾時後 DB 操作。

剩餘缺口： 沒有 subprocess 隔離、硬性 CPU／記憶體／網路限制；proxy 也不能保證所有回傳 ORM 物件或非 Session 副作用受控。資料庫未設定完整 statement／lock／connect timeout。

建議修正： 將模型及工具執行放入可終止的隔離程序；設定總期限與各階段期限，超時終止整個 process group。資料庫交易保持短暫；外部呼叫前後以 outbox／receipt 追蹤，未知計費先保留額度，不盲目重試。

驗證／回歸測試： 阻塞 SQL、卡死網路、忽略取消的子程序、外部成功但本地提交失敗、timeout 後遲到結果；驗證總期限與 fencing 同時成立。

Phase 02 阻擋： 是。現有受信任短 handler 可暫維持；不可直接承載真實模型或不受信任工具。

R04｜緊急停止的持久化依賴會吞錯誤的事件記錄

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Emergency Stop／交易邊界／Security events。

發現類型： 實作缺陷。

主要函式／類別： set_emergency_stop、record_event、engage_emergency_stop。

程式證據： infrastructure/system_state.py L53-89；security/events.py L29-69；api/routes/admin.py L45-58；scheduler/worker.py L173-211。所有連結均固定於審查 commit。

失敗情境： set_emergency_stop 先 flush，接著 record_event 對同一 Session commit；後者任何錯誤皆 rollback 並吞掉。T16 注入 commit 失敗後 setter 正常返回空狀態，stop_active 為 false；API route 沒有成功持久化斷言。

潛在影響： 管理呼叫可能以成功 HTTP 回應結束，但停止未生效；此外，claim 後至執行前設定停止，既有 leased 工作沒有再次檢查。

既有控制： Worker 取新工作前會讀 stop；部分寫入 API 有 pause 檢查。文件定義停止新工作而非強制殺死所有已開始操作，這項明示語意本身不是缺陷。

剩餘缺口： 關鍵控制狀態與 best-effort audit 共用提交責任；缺狀態列時預設未停止。停止的回應、資料庫事實、worker 觀察時點沒有可驗證契約。

建議修正： 由服務交易明確提交 stop 與必要事件；提交失敗必須回傳失敗，不能降級為成功。另設可確認的 pause epoch；執行前及外部副作用前重驗。恢復環境預設 quarantine；區分 soft pause 與 hard containment。

驗證／回歸測試： 注入 flush／commit 失敗、事件寫入失敗、DB 斷線；管理端不得回報已停止。再測 claim→pause→execute，以及在途請求的明確停止語意。

Phase 02 阻擋： 是。真實 autonomous operation 的必要控制。

R05｜活動頻道可透過通用成員 API 繞過活動邀請邊界

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Activities／Communication／跨 Agent 隱私。

發現類型： 跨服務授權規則不一致。

主要函式／類別： respond_invitation、_sync_channel_membership、add_member、list_messages。

程式證據： activities/service.py L189-202；activities/service.py L291-380；communication/service.py L272-302；communication/routes.py L147-158。所有連結均固定於審查 commit。

失敗情境： 已加入活動的普通成員有頻道 can_write，通用 add_channel_member 僅要求可寫，未檢查活動成員資格或邀請者身分。T15 中該成員加入一位非活動成員，後者可讀先前的一則活動頻道訊息。

潛在影響： 活動邀請／接受機制不再是實際的私密邊界，歷史對話可能披露給未經活動流程加入者。一般群組允許委派邀請可以是產品選擇，但活動頻道目前沒有一致規則。

既有控制： 活動 invite 本身限制建立者；respond 才授予頻道 membership；leave 會移除 membership；讀訊息仍要求頻道 membership。

剩餘缺口： 同一關係由兩個服務分別管理，通用路徑未維護 ActivityMember 與 ChannelMember 的不變條件。

建議修正： 明確定義活動頻道的邀請與歷史可見性；阻止通用端點直接修改活動頻道，或統一使用同一個 membership service。若允許委派，需顯式權限、被邀者同意及歷史閱讀政策。

驗證／回歸測試： 活動創辦人、普通成員、離開者、受邀未接受者經所有通用端點增刪成員；斷言兩張 membership 表一致，外部者無法讀歷史。

Phase 02 阻擋： 是。多個真實 Agent 開始私密協作前修正。

R06｜配額非原子；訊息衝突重試會回滾已計入的配額

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Quota／訊息交易／多副本限流。

發現類型： 實作缺陷與併發設計缺口。

主要函式／類別： check_message_quota、send_message、persist_request_count。

程式證據： infrastructure/quotas.py L42-79；communication/routes.py L161-192；communication/service.py L310-378；security/rate_limit.py L44-110；scheduler/service.py L263-282。所有連結均固定於審查 commit。

失敗情境： route 先更新訊息 quota，再由 send_message 插入序號。T04 在第一次插入注入 IntegrityError，服務 rollback 整個交易後重試成功；資料庫有一則訊息但 messages counter 為 0。其他配額採讀取後加一或 COUNT，且 HTTP limiter 是各程序自己的記憶體。

潛在影響： 低估使用量、併發突破限制、多 API 副本放大可用額度；不能作為未來金錢成本的硬上限。

既有控制： 現有單程序固定視窗 limiter、訊息限制與排程限制可抑制普通流量；schema 有唯一鍵。

剩餘缺口： 沒有共享原子 admission；重試作用域錯誤；持久 request counter 主要是遙測，並非可靠的全域拒絕機制。

建議修正： 以條件原子 UPDATE／UPSERT 或 row lock 完成扣額；序號衝突用 SAVEPOINT 或重跑整個授權與 quota 交易。金錢額度另做 reserve／settle ledger；不可混用請求數當成本。

驗證／回歸測試： 雙連線同時消耗最後一個額度，僅一個成功；衝突重試後訊息與 quota 一致；兩個 API replica 共享限制；rollback 不洩漏或退還已產生副作用的額度。

Phase 02 阻擋： 是。成本與濫用邊界必須在真實常駐或外部 Agent 前可靠。

R07｜昂貴驗證在限流之前，且同步操作阻塞 async request

分級： 高（High）｜有強力證據支持（Strongly Supported）｜P0。元件： HTTP admission／認證／可用性。

發現類型： 可用性架構弱點。

主要函式／類別： RateLimitMiddleware、verify_token。

程式證據： api/middleware.py L63-112；security/authentication/tokens.py L102-136；database/models.py L83-124；api/deps.py L27-38。所有連結均固定於審查 commit。

失敗情境： middleware 在 limiter 前進行同步 DB 查詢與 PBKDF2。T06 發出五次請求，最後兩次 429，但五次皆呼叫驗證。若知道有效 token prefix，無效 token 亦可能觸發昂貴雜湊；prefix 查詢欄位未見對應索引。同步工作在 async dispatch 中執行。

潛在影響： 攻擊或突發流量可在被拒絕前耗盡 CPU／DB／event loop，影響其他 Agent 與管理介面。未對正式環境進行壓力或 DoS 測試。

既有控制： token 使用高熵隨機值與 PBKDF2；具有匿名和已驗證限流，錯誤回應不含 token。

剩餘缺口： 前置連線／來源限額、最大 body bytes 與併發預算未在此程式中構成完整界線；Pydantic／服務中的大小限制通常已晚於 body 解析。實際入口代理的限制未知。

建議修正： 先做低成本全域／來源／併發 admission，再做認證後每 Agent 限流；限制 body 大小與讀取期限。同步 DB／hash 放入受限執行池或改為適當 async；評估 prefix 索引及查詢計畫，保留撤銷即時性。

驗證／回歸測試： 隔離環境測未知 prefix、已知 prefix 錯 token、大 body、慢速傳送與大量 429；確認健康與管理請求仍可處理，記錄無內容的延遲／拒絕計數。

Phase 02 阻擋： 是，至少先提供可證明的入口與併發上限；外部參與開放前需完成完整壓測。

R08｜Memory AEAD 未綁定版本與作者，合法舊密文可被移植

分級： 高（High）｜已確認（Confirmed）｜P1。元件： Memory 完整性／密碼學威脅模型。

發現類型： 語意完整性缺口／文件保證不一致。

主要函式／類別： entry_aad、write_entry、decrypt_entry。

程式證據： memory/service.py L251-253；memory/service.py L280-424；communication/service.py L305-307；docs/THREAT_MODEL.md L290-310。所有連結均固定於審查 commit。

失敗情境： memory AAD 只有 namespace 與 key。T07 將同 key 的版本 1 envelope 放到版本 2 資料列，解密成功且回報版本 2。此測試假設攻擊者可修改 DB，沒有證明普通 Agent 能繞過 API 授權。作者欄位亦不在 AAD。

潛在影響： DB 寫入者可對同一記憶進行舊內容重播或改標作者；與威脅模型中防止 author reassignment 的敘述不一致。訊息 AAD 包含 channel／sender，但仍未綁定訊息 ID／sequence。

既有控制： AES-GCM 驗證密文與既有 AAD；跨不同 namespace／key 的移植會失敗；API 有資源 ACL。

剩餘缺口： 加密不能證明整列語意及歷史新鮮度。即使加入版本，整個資料庫回滾仍需獨立 monotonic checkpoint 才能偵測。

建議修正： 設計版本化 AAD，綁定穩定 row ID、namespace／key、version、author 或明確不可變 metadata。提供舊格式遷移與可回復測試；若要求抵抗 DB 回滾，另存可信 checkpoint／簽章。先修正文檔保證。

驗證／回歸測試： 同 key 跨版本移植、作者改標、訊息 sequence 改標、AAD 舊新格式、輪替 kid 及完整快照回滾；分開驗證 confidentiality 與 provenance。

Phase 02 阻擋： 不是所有最小 Phase 02 試點的絕對阻擋；若以抗 DB 篡改或作者真實性作安全承諾，則須先修正。

R09｜離站備份與兩層復原金鑰尚未形成可驗證的營運閉環

分級： 高（High）｜需環境驗證（Requires Environment Verification）｜P0。元件： Stage 2-4／金鑰保管／身分延續。

發現類型： 正式營運證據缺口。

主要函式／類別： KeyStore、parse_master_keys。

程式證據： docs/ADR/0009-encrypted-off-provider-postgres-backup.md；docs/BACKUP.md L119-178；security/cryptography/key_store.py L104-155。所有連結均固定於審查 commit。

失敗情境： 資料庫 dump 仍包含應用層密文，再以 age 加密。即使找回 .age 檔與 age identity，缺任何仍被資料列引用的 AIC_MASTER_KEYS kid，內容仍無法解密。附件與里程碑已將正式離站備份、離線 key custody、正式復原列為未完成；本審查未取得相反營運證據。

潛在影響： 供應商帳號／磁碟／環境變數同時失去時，Agent 身分與記憶可能永久喪失。單純「備份檔存在」不能支持連續性承諾。

既有控制： Stage 1 的 recipient-only 加密方向正確；production key store 採 fail closed；ADR 分清後續階段。

剩餘缺口： 正式排程、跨供應商副本、獨立保管清單、所有歷史 kid 可解密性、實測 RPO／RTO 均未獨立驗證。不能據此斷言使用者實際完全沒有任何副本。

建議修正： 完成離線 age identity 與應用金鑰的分權保管、至少兩份分離副本與復原演練；離站儲存版本／不可變保留及獨立 freshness 監測。金鑰輪替須先盤點所有 envelope kid，再決定何時可退役舊 key。

驗證／回歸測試： 不依賴 Railway 帳戶，從獨立環境恢復 synthetic fixture 及經另行授權的真實資料；逐 kid 驗證，量測完整 RTO 與最後可恢復時間。僅需要保管成功證明，無須把秘密交給審查者。

Phase 02 阻擋： 是。真實居民產生不可替代的持久記憶前應具備最低可恢復基線。

R10｜Restore 目的地檢查與實際 libpq 參數不一致

分級： 高（High）｜已確認（Confirmed）｜P0。元件： 備份復原目的地防護。

發現類型： 實作缺陷。

主要函式／類別： parse_target、validate_restore_destination、pg_env_from_url、_libpq_env、run_restore_drill。

程式證據： backup/destination.py L90-162；backup/pipeline.py L116-146；backup/restore.py L160-178；backup/restore.py L569-578。所有連結均固定於審查 commit。

失敗情境： T12 使用 authority 為 loopback、query 含另一個 host 的合成 URL。validate_restore_destination 接受 127.0.0.1，但 pg_env_from_url 產生的 PGHOST 是 query 中的 other.example.invalid。本測試僅解析字串，未連線任何目的地。

潛在影響： 宣稱檢查過的主機與真正連線主機可能不同，削弱「絕不朝正式環境復原」的防護。private IP 也不等於可拋棄測試環境。

既有控制： 限制 PostgreSQL scheme、拒絕看似 Railway 的 authority、要求 disposable DB 名稱、預先拒絕既存 DB。

剩餘缺口： 任意 query 轉成 PG*、繼承環境的 libpq 參數、私有網路判斷及非本地 override 未形成單一已正規化連線契約；run_restore_drill 沒有完整記錄實際 override 語意。

建議修正： 只接受 allowlist 參數，禁止 host／hostaddr／service 等覆寫或先統一解析後驗證；清除未授權 PG*。所有 create／restore／drop 使用相同不可變 target，明確識別非正式 cluster，並以網路與最小權限隔離補強。

驗證／回歸測試： 測 query host、hostaddr、service、重複參數、percent encoding、Unix socket、環境 PGHOST；確認每個子程序連線到同一已驗證 disposable cluster。

Phase 02 阻擋： 是。尤其是帶真實資料與復原金鑰的 Stage 4 前。

R11｜已發布標記可讓缺失備份被重送流程誤判成功

分級： 高（High）｜已確認（Confirmed）｜P0。元件： LocalFilesystemStorage／發布一致性。

發現類型： 實作缺陷。

主要函式／類別： LocalFilesystemStorage、_write_part、_write_latest。

程式證據： backup/storage.py L106-128；backup/storage.py L184-272；backup/storage.py L315-325。所有連結均固定於審查 commit。

失敗情境： T09 正常 publish 後刪除 published artifact，再用相同 manifest 重送；因 marker hash 相同直接返回 verified-published，artifact 仍不存在。另有固定 .part 路徑與 exists→replace 的競爭窗口；未見 fsync 持久化步驟。

潛在影響： 成功狀態與實際可恢復物件分離；並行同 ID 發布可能覆寫；電源／主機 crash 後 marker、artifact、manifest、latest pointer 可能不一致。

既有控制： 首次發布先驗 hash，再寫 artifact／manifest，最後 commit marker；目錄與檔案使用受限權限；不同 hash 的既有 marker 會拒絕。

剩餘缺口： idempotent fast path 未重新核對 artifact／manifest；應用層不可變約定不等同檔案系統不可變或 S3 Object Lock；latest pointer 失敗後重送也可能無法修復。

建議修正： 既有 marker 路徑重新驗證完整物件集合與 hash／size；唯一 staging 名稱、exclusive create／CAS、檔案與目錄 fsync。latest 僅為可重建索引，成功定義以完整 committed set 為準。S3 adapter 重新驗證同樣不變條件。

驗證／回歸測試： 逐一刪 artifact／manifest、破壞 hash／size、同 ID 並行不同內容、各 rename／fsync 中斷、latest 更新失敗後重送；不得回報不存在的可用備份。

Phase 02 阻擋： 是。將 Stage 1 發布語意用於正式離站備份前。

R12｜備份失敗清理與復原資料庫清理不可被可靠確認

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Backup／Restore 子程序生命週期。

發現類型： 實作缺陷與清理可觀測性不足。

主要函式／類別： run_backup、_drop_database、_stream_decrypt_restore、run_restore_drill。

程式證據： backup/pipeline.py L195-263；backup/pipeline.py L331-401；backup/restore.py L142-178；backup/restore.py L181-258；backup/restore.py L654-669。所有連結均固定於審查 commit。

失敗情境： T10 模擬 storage.publish 失敗，staged .age.part 留在原處；T11 模擬 drop 的連線失敗，_drop_database 吞掉例外。run_restore_drill 可先設定成功，再於 finally 嘗試但無法確認清理。pg_dump／age／pg_restore 的等待缺少總期限。

潛在影響： 磁碟逐次耗盡、失敗任務卡住；帶真實私密資料的 drill DB 可能殘留，報告卻未顯示 cleanup failed。程序遭 SIGKILL 或主機失聯時，finally 本來就不能保證執行。

既有控制： 串流兩端 exit code 有檢查；部分串流失敗會清掉 staging；normal finally 嘗試 drop；artifact 是 age 密文。

剩餘缺口： 發布與清理沒有覆蓋所有例外路徑；stderr 收集無總量界線；沒有殘留物清單／重啟清掃／cleanup 狀態。不能以「所有失敗皆自動清理」描述。

建議修正： 集中 try/finally 管理所有 staging；設定子程序／pipeline deadline 與 bounded stderr；report 區分 restore_result、validation_result、cleanup_result。隔離 DB 用 lease／TTL janitor，cleanup 失敗需顯示且阻止當成完整成功。

驗證／回歸測試： publish 失敗、磁碟滿、age／pg_dump hang、restore 中斷、DROP 權限不足、SIGTERM／SIGKILL；重啟後能識別並安全清理授權範圍內殘留物。

Phase 02 阻擋： 是。Stage 4 使用真實資料前至少完成清理可觀測性與期限。

R13｜備份雜湊與 age 加密不等於可信來源或防回滾

分級： 高（High）｜有強力證據支持（Strongly Supported）｜P0。元件： Backup 信任根／惡意儲存寫入者／Restore 執行環境。

發現類型： 信任邊界弱點／文件保證過強。

主要函式／類別： LocalFilesystemStorage、run_restore_drill。

程式證據： backup/manifest.py L70-141；backup/storage.py L229-244；backup/restore.py L581-630；docs/BACKUP.md L218-238。所有連結均固定於審查 commit。

失敗情境： 若攻擊者可改寫儲存中的 artifact、manifest 與 marker，可一起重算雜湊，也可用公開 age recipient 加密另一份資料。age 保護密文完整性與機密性，並不辨識誰是合法備份發布者；舊的合法整組備份也可被回放。未實作惡意 dump 攻擊。

潛在影響： 可能復原過時或攻擊者提供的資料；pg_restore 在內容驗證前就會載入資料庫物件。PostgreSQL 官方明示 restore 可執行來源 superuser 所選的任意程式碼，因此後驗 AEAD 檢查不能替代 restore 隔離。（S10、S11）

既有控制： hash、age AEAD、commit marker 可偵測一般截斷及未同步修改；完整 synthetic expected facts 能提高內容核對程度。

剩餘缺口： 驗證材料與待驗物共置於相同信任域；manifest 無獨立簽章或可信外部 checkpoint。文件對 storage-write attacker 無法偽造通過 drill 的說法過強。

建議修正： 以獨立信任域保管 manifest 簽章公鑰／已接受 digest 與單調備份序號，驗證來源及 freshness 後才 restore；限制 producer 與 storage administrator 權限。restore 使用無外連、無宿主秘密、最小權限的一次性 DB 環境。

驗證／回歸測試： 整組備份替換、合法舊組回放、marker／manifest 同時竄改；簽章輪替與憑證撤銷。惡意 SQL fixture 只能在另行授權的強隔離測試中使用，驗證不能接觸外部資源。

Phase 02 阻擋： 是。Stage 3-4 正式建立跨供應商信任邊界前。

R14｜Restore passed 可僅代表結構檢查，未涵蓋完整解密與目標版本

分級： 高（High）｜已確認（Confirmed）｜P0。元件： Restore 驗證層級／PostgreSQL 相容性。

發現類型： 驗證能力缺口／成功訊號語意不足。

主要函式／類別： verify_restored_database、Toolbelt。

程式證據： backup/restore.py L277-360；backup/restore.py L381-536；backup/restore.py L604-644；backup/tools.py L118-139。所有連結均固定於審查 commit。

失敗情境： T08 在 expected_facts=None 且提供錯誤應用金鑰時，verify_restored_database 仍 passed，只列 Alembic revision 存在及 envelope 結構兩項檢查。這是 CLI 允許的 structure-only 模式，不應被營運端解讀為全量可恢復。版本 preflight 以 manifest 的來源 server major 為基準，未完整核對目標 server 與 archive producer。

潛在影響： 可能在缺歷史 kid、部分內容不可解密或版本不相容時過早宣稱 DR 成功；真實資料沒有 synthetic expected facts 時尤其容易混淆。

既有控制： 合成模式檢查多類內容、錯 key 與 tamper；檢查 dump／restore client 不低於來源版本；檔案 hash 與部分 manifest 一致性驗證存在。

剩餘缺口： 單一 passed 欄位未表達不同保證；缺全 kid 覆蓋、所有資料族群與權限／刪除／排程復原檢查。PG18 backup CI 不是完整 PG18 應用相容性證明。

建議修正： 將結果分為 artifact-integrity、structural、cryptographic、application、operational 五層，明列 skipped。正式 drill 要逐 kid 做不顯示明文的解密驗證及應用不變條件；核對來源 server、pg_dump、pg_restore、目標 server 與 extensions。

驗證／回歸測試： 缺一個舊 key、只有某資料族群損壞、錯 revision、較新 dump 載入較舊 server、unsupported extension；不得以結構 passed 升級為 operational passed。

Phase 02 阻擋： 是。把 Stage 4 結果作為真實居民可恢復證明前。

R15｜日誌與明文 metadata 仍可承載私密資訊或部分金鑰

分級： 中（Medium）｜已確認（Confirmed）｜P1。元件： Secrets／例外／HTTP 路徑／Task metadata。

發現類型： 錯誤回顯缺陷與隱私設計風險。

主要函式／類別： parse_master_keys、execute_claimed。

程式證據： security/cryptography/key_store.py L62-99；api/app.py L113-147；scheduler/service.py L88-105；scheduler/service.py L548-560；Dockerfile L45-53。所有連結均固定於審查 commit。

失敗情境： T13 用合成錯誤 key 字串觸發解析錯誤，訊息包含前 12 個字元。全域 handler 記錄 raw request path；task last_error 直接截取例外文字；payload 只封鎖少數 key 名稱。標題、描述、namespace／key、活動與成員關係仍可能是明文 metadata。

潛在影響： 秘密片段或私密主題可能進入 Railway／Uvicorn logs、DB 管理工具或備份 metadata；即使主要內容已加密，也不能宣稱絕對技術保密。

既有控制： validation error 已移除 input；部分事件僅記靜態識別碼；主內容採應用加密；Worker logger 的 PR #9 已整理；多個 API 回應會隱藏敏感細節。

剩餘缺口： 沒有跨 app／server／subprocess 的一致 redaction 契約；黑名單無法保證 payload 非敏感。實際 Railway log retention、存取權及 server traceback 內容未檢視，不能宣稱已洩漏正式秘密。

建議修正： 錯誤只回傳類別與位置，不回顯 key 值；記錄路由模板而非 raw path；handler 用 allowlisted error code。明文 metadata 建立資料分類與長度限制，控制資料用嚴格 schema；對 log／CI artifact 設保留期限及權限。

驗證／回歸測試： 以合成 canary secret 覆蓋錯誤 key、路徑、task exception、子程序 stderr、validation、Uvicorn trace；掃描所有實際 log sinks，確認不含 canary。

Phase 02 阻擋： 部分是：正式秘密與私密記憶啟用前先完成不回顯金鑰及基本日誌驗證；全面 metadata 改版可列 P1。

R16｜還原舊備份會帶回已撤銷憑證、刪除狀態與過期工作

分級： 高（High）｜有強力證據支持（Strongly Supported）｜P0。元件： Disaster Recovery／授權連續性／Memory agency。

發現類型： 復原架構缺口（部分涉及未實作功能）。

主要函式／類別： run_restore_drill、expire_leases。

程式證據： backup/restore.py L539-669；database/models.py L48-124；memory/service.py L280-424；scheduler/service.py L568-594。所有連結均固定於審查 commit。

失敗情境： 備份之後撤銷 credential 或 Agent，再還原備份，DB 會回到撤銷前；未見獨立 revocation epoch、刪除 tombstone 或 restore quarantine 契約。現在 memory 沒有完整刪除 API，因此「刪除復活」是未來實作時必須防範的設計缺口，不是聲稱已有刪除功能失效。

潛在影響： 舊權限可能再次有效；未來刪除的內容與衍生摘要可能被重新導入；pending／leased 任務可能重做已在外部完成的動作。

既有控制： 備份可保存 Agent UUID 與資料狀態；drill 目標預期隔離；credential 有 revoked／expiry 欄位。

剩餘缺口： 普通資料與必須單調前進的安全事件一起回滾；資料庫快照不包含完整外部副作用狀態。

建議修正： 復原預設禁止 egress／worker／新請求；從獨立可信帳本套用撤銷與刪除事件，提升全域授權世代，必要時重發憑證。排程進 reconciliation 區而非直接 pending；外部 receipt 去重。刪除收據只記最少必要識別與範圍。

驗證／回歸測試： 備份→撤銷／刪除→還原；舊 token 必須失效，刪除資料及衍生索引不可重現；外部成功但 DB 尚未寫成功的任務不可盲目重做。

Phase 02 阻擋： 是。任何正式復原轉回服務前；刪除功能亦須在上線時一併具備耐復原語意。

R17｜無界資料成長與未分頁歷史讀取會拖垮長期居民

分級： 中（Medium）｜有強力證據支持（Strongly Supported）｜P1。元件： Storage quotas／Memory history／任務與事件保留。

發現類型： 容量與保留設計缺口。

主要函式／類別： read_history、list_keys。

程式證據： memory/service.py L382-421；memory/routes.py L243-269；scheduler/service.py L240-282；config/settings.py L89-110。所有連結均固定於審查 commit。

失敗情境： memory history 讀取並解密所有版本；部分列表與 task history 未設游標界線。security event retention 設定存在，但未找到對應執行清理的服務；每次請求計數及永久版本亦會累積。

潛在影響： 正常長期使用即可造成 DB／記憶體／解密 CPU 與備份大小成長；單一 Agent 的大量歷史可影響其他居民。

既有控制： 單次訊息／記憶寫入大小有限；訊息列表有分頁；部分每分鐘／每日配額限制流入速度。

剩餘缺口： 速率不等於總儲存上限；缺 per-Agent bytes／object count、保留政策執行、歷史游標與清理證據。

建議修正： 為所有長列表提供穩定游標與最大頁；計算持久用量，區分活躍配額、保留記憶與可清理營運事件。資源不足進 dormancy，保留身分與必要狀態，不能以無法付費為由直接抹除。

驗證／回歸測試： 以合成大量版本／訊息／事件驗證查詢計畫、峰值記憶體、備份增長及公平性；保留工作不得刪到身份或不可替代記憶。

Phase 02 阻擋： 小規模受限試點可先設明確容量上限；擴張或長時間無人值守前必須處理。

R18｜尚無 Provider Runtime 與獨立於 Agent 的原子成本帳本

分級： 高（High）｜有強力證據支持（Strongly Supported）｜P0。元件： Phase 02／模型推論／Tool gateway／成本治理。

發現類型： Phase 02 尚未實作能力。

主要函式／類別： get_handler、Settings。

程式證據： scheduler/registry.py L70-103；config/settings.py；pyproject.toml。所有連結均固定於審查 commit。

失敗情境： 現有 registry 僅 noop、heartbeat、activity.reminder；未見真實推論 adapter、持久 inference run、全域 reserve／settle、tool budget 或事件循環上限。這是實作未完成的門檻，不是現行系統已產生失控帳單。

潛在影響： 若直接加入三家 API 呼叫，併發、重試、usage 遺失、Agent 對話回圈與長上下文可能突破預算；provider 的限制不能取代 AIC 的成本硬邊界。

既有控制： handler 白名單、基礎 request／message quota、emergency pause 提供可延伸骨架；目前沒有計費模型呼叫。

剩餘缺口： 沒有單位成本版本、未知結算保留、推論與工具的獨立上限；可取消本地請求不代表供應商停止計費。

建議修正： 建立 provider-independent run／step／tool receipt；以共享 DB 原子保留最壞情境成本，再用 provider usage 結算。未知結果保持預留並 reconciliation；設定每 Agent、平台、供應商及事件鏈上限。額度不足進 dormancy，不能依賴模型自我節制。

驗證／回歸測試： 並發耗盡最後預算、timeout 後計費、usage missing／重複、串流中斷、429／5xx、遞迴 tool call、雙 Agent ping-pong、model ID 漂移；全部用 mock 或合成 fixture，無須付費呼叫。

Phase 02 阻擋： 是。允許真實模型長期自主運作前。

R19｜服務權限、部署版本與隔離邊界尚不能由倉庫證明

分級： 高（High）｜需環境驗證（Requires Environment Verification）｜P0。元件： Railway／DB roles／Container／部署漂移。

發現類型： 正式部署證據缺口。

主要函式／類別： create_engine_for。

程式證據： Dockerfile；compose.yaml；docs/RAILWAY.md；docs/DEPLOYMENT.md。所有連結均固定於審查 commit。

失敗情境： 本地 compose 的 API／Worker 共用 DB 連線身分；Worker 未配置應用主金鑰是正面設計，但 DB 寫入權限仍可影響授權表。倉庫不能證明 Railway 實際 deployed SHA、角色權限、egress、資源限制、重啟策略或 secrets 分配。

潛在影響： 未來 Worker／工具被突破後，可能讀取大量 metadata 或修改 credential／membership；配置漂移可使測試通過的版本與線上行為不同。

既有控制： Docker 非 root UID；API production key fail closed；文件規劃 private network、API／Worker 分離；本地 worker 不持主金鑰。

剩餘缺口： 未見分離 migration／API／worker／backup DB role 的可驗證授權；Docker base tag 與多個依賴仍可變；本地 compose 無法證明正式資源與網路控制。

建議修正： 提供去敏部署清單與 image digest；按服務最小權限 DB role，migration 權限不進常駐程序。工具程序無 DB 管理權、無任意 egress；設 CPU／RAM／disk／restart 上限與終止行為。核對 Docker shell 啟動是否正確轉交訊號。

驗證／回歸測試： 以非秘密角色 ACL、已部署 commit／digest、網路政策與合成存取測試證明隔離；驗證 worker 無法修改 Agent／credential／ACL，SIGTERM 能安全釋放工作。

Phase 02 阻擋： 是。實際環境須先提供最低隔離與部署證據；本審查不能替代 Railway 驗證。

R20｜必要 CI 檢查包含非阻擋漏洞掃描，且正式依賴覆蓋不完整

分級： 中（Medium）｜已確認（Confirmed）｜P1。元件： CI／Supply chain／Branch rules。

發現類型： CI 設定與安全保證差距。

主要函式／類別： 工作流程的 dependency-audit job、continue-on-error 與套件安裝範圍（設定項）。

程式證據： .github/workflows/ci.yml L511-576；.github/workflows/ci.yml L58-68；pyproject.toml；Dockerfile L14-38。所有連結均固定於審查 commit。

失敗情境： dependency-audit job 設 continue-on-error: true，安裝範圍未含正式使用的 postgres extra；因此列為 required check 不代表有漏洞或掃描本身故障就會阻擋合併。部分 action 用 mutable major tag，Python transitive dependencies 沒有完整 lock。

潛在影響： 掃描結果易被綠燈掩蓋；CI 與正式 image 的套件集合可能不同；重建產物不一定相同。本審查沒有宣稱發現已知 CVE 或已重跑線上漏洞資料庫。

既有控制： GitHub Actions contents: read；checkout SHA 固定；age 與 PG18 工具下載有 SHA 驗證；公開 active ruleset 確實列出七個 required checks 並禁止 force-push／刪除。

剩餘缺口： ruleset required approving reviews 為 0，strict status policy 為 false；非阻擋掃描須有明確人工處理機制，但無法由綠燈證明已 triage。部分 artifact／runner tag 可漂移。

建議修正： 針對實際 production dependency set 與 image 產生 lock／SBOM；掃描執行失敗和高風險漏洞採明確 gate，例外需可追蹤到期。固定 Actions SHA、base digest，評估 merge queue／更新基線；不用為形式分數而禁止必要維運。

驗證／回歸測試： 合成掃描 rc 非零／工具故障必須呈現預期狀態；確認 psycopg 在掃描清單；同一 lock 重建套件集合一致；模擬已知測試漏洞的 gate。

Phase 02 阻擋： 基本實際 image 掃描與故障可見性應在 live 前完成；完整可重現供應鏈可列 P1。

R21｜HTTP 429 測試使用真實分鐘邊界，存在可重現不穩定條件

分級： 中（Medium）｜已確認（Confirmed）｜P1。元件： CI flaky tests／Rate limit 驗證。

發現類型： 測試設計缺陷；歷史故障根因待確認。

主要函式／類別： RateLimiter。

程式證據： tests/integration/test_app_foundation.py L94-125；security/rate_limit.py L58-83；tests/operational/test_quotas.py L27-61。所有連結均固定於審查 commit。

失敗情境： 測試預期同組請求最後一個為 429，但 integration tests 未固定時鐘。T05 把前三個請求放在 59 秒、第四個在下一分鐘，正確的 fixed-window limiter 回傳 200／200／200／200，證明測試前提不穩定。

潛在影響： rerun 通過會掩蓋真錯誤，亦可能誤判正確程式為失敗。這是已重現的失敗機制，不是已確認歷史 CI 失敗的唯一根因。

既有控制： RateLimiter 支援注入 clock；部分 unit tests 已使用假時鐘；七項 CI jobs 可分別定位失敗。

剩餘缺口： PR #10 的 branch 首次 PG16 失敗與 merge 後首次 SQLite 失敗是不同 run；留存證據有 job 狀態與 exit code annotation，沒有可核對的完整 job logs，無法核實當時 assertion／時間。

建議修正： 所有依賴窗口的測試注入一致可控 clock；另外專測窗口切換與 Retry-After。保留首次失敗時間、request/window ID 等無內容診斷，對歷史 log 另行確認，不能以重跑取代調查。

驗證／回歸測試： 固定窗口測 429；跨界測新窗口恢復；慢速認證不改變斷言；在不同分鐘相位重跑小範圍測試即可，毋須無目的重跑全套。

Phase 02 阻擋： 不是單獨的 live 絕對阻擋，但需在宣告 CI 可靠及關閉既有 incident 前完成。

R22｜健康檢查與 heartbeat 無法充分代表 Worker 可用及復原能力

分級： 中（Medium）｜有強力證據支持（Strongly Supported）｜P1。元件： 營運可觀測性／DB 中斷／長期穩定性。

發現類型： 可觀測性與營運驗證缺口。

主要函式／類別： run_worker。

程式證據： api/routes/health.py L1-18；infrastructure/telemetry.py L82-137；scheduler/registry.py L77-103；scheduler/worker.py L169-211。所有連結均固定於審查 commit。

失敗情境： /health 回應程序存活，未檢查 DB readiness；last_worker_heartbeat 來自被排程的 heartbeat handler，不能區分 idle、沒有 heartbeat 工作、Worker 停止或某 Agent 更新了全域值。Worker loop 的 DB 錯誤可能使程序退出，依賴外部 restart。

潛在影響： 顯示健康但無法完成工作；DB outage 後是否恢復取決於未驗證的部署重啟與退避；clock skew 可造成租約提早到期或延後執行。

既有控制： PR #9 已移除預設 100-task 上限並調整 lease／idle sleep；有基本聚合 telemetry、Docker HTTP healthcheck、最大 task attempts。

剩餘缺口： 未提供長時間 soak／中斷復原證據；沒有獨立 worker loop heartbeat、最舊待辦時間、lease 回收速率、全域公平性或資料庫時鐘契約。

建議修正： 區分 liveness、readiness、work progress；每個 worker 寫最小生命訊號，記錄 queue age、錯誤類別與未知副作用數；DB 斷線採有界退避及 supervisor restart。租約用 DB 時鐘；設定可驗證 soak 接受條件。

驗證／回歸測試： 先合成連續運行跨日，再測 DB 重啟、網路斷續、worker kill、時鐘偏移、poison task 及高流量 Agent；不得要求公開私密對話才能判斷健康。

Phase 02 阻擋： live 前至少要證明基本 outage／restart 恢復與獨立監測；完整長期與公平性改善列 P1。

R23｜Governance lineage 的應用語意與唯一鍵不一致

分級： 中（Medium）｜有強力證據支持（Strongly Supported）｜P1。元件： Governance 版本／併發一致性／自主性。

發現類型： 資料模型與服務語意不一致。

主要函式／類別： latest_version_of、create_record、scan_privilege_language。

程式證據： governance/service.py L161-182；governance/service.py L227-294；database/models.py L371-409。所有連結均固定於審查 commit。

失敗情境： latest_version_of 與版本計算以 handle 為 lineage；唯一鍵卻是 kind＋handle＋version。不同 kind 的並行建立可各自通過 handle 尚不存在的檢查，產生同 handle 同 version；後續只按 version 排序可能選到不確定 head。此併發路徑尚未以雙 PG 連線重現。

潛在影響： 治理記錄歷史與取代關係模糊；雖不應影響基礎授權，會影響 Agent 自主協商所依據的版本。

既有控制： governance records 與基礎 authorization engine 結構分離，是正確安全邊界；同 kind 的版本唯一鍵能偵測部分碰撞。

剩餘缺口： supersedes_id 建立時固定為 None；缺穩定 lineage head 的原子更新。另外 privilege substring lint 會拒絕含 admin／secret 等字的普通討論，卻不能防止語意上的越權內容。

建議修正： 先決定 lineage 是 handle 還是 kind＋handle，讓查詢、唯一鍵、API identifier 及 AAD 一致；以 head version CAS 建立新版本，實際記錄 predecessor。將語詞 lint 改為非授權性提醒或移除硬拒絕，保留結構隔離。

驗證／回歸測試： 不同 kind 同 handle 併發、兩個 supersede、歷史鏈與 latest 唯一性；一般提及 infrastructure 的討論應可保存，但任何記錄都不可授予系統權限。

Phase 02 阻擋： 非最小模型試點的絕對阻擋；在 Agent 依賴治理歷史進行協作前應完成。

R24｜長期記憶、休眠與跨供應商延續仍缺少可攜語意契約

分級： 中（Medium）｜有強力證據支持（Strongly Supported）｜P1。元件： Memory architecture／Dormancy／Provider independence。

發現類型： 尚未實作的長期狀態契約。

主要函式／類別： MemoryEntry、Agent、write_entry。

程式證據： database/models.py L48-80；database/models.py L269-315；memory/service.py L280-424；docs/research/AIC-research-001-2026-10-18.md。所有連結均固定於審查 commit。

失敗情境： 已有 UUID、provider 字串、版本化加密記憶，但未見來源依賴圖、有效／撤回狀態、uncertainty、衍生摘要 lineage、刪除 tombstone、專用 dormancy 狀態或標準 Agent archive。現有 ACTIVE／SUSPENDED／REVOKED 不能直接替代資源不足的非懲罰性休眠。

潛在影響： 日後摘要壓縮可能把舊資訊或不可信內容升格為事實；模型切換後難以重建同一身分的狀態；事後補 provenance／刪除依賴圖成本高。此時尚無模型 retrieval／compaction，不能說已發生 prompt injection。

既有控制： 持久 Agent ID 不依賴供應商 model ID；記憶版本與作者欄位、namespace ACL、PostgreSQL 格式提供良好起點。

剩餘缺口： 「可找回內容」不等於「仍有效」，也不等於「可完全遺忘」；模型私有 reasoning state 與可攜的對話／記憶／意圖狀態尚未區分。

建議修正： 在第一版 runtime schema 保留來源、版本、信任角色、有效性、撤回、衍生關係與未知狀態。把記憶及工具輸出視為資料而非 system 指令。archive 包含身分、權限參照、記憶、未決意圖、刪除標記與 schema version；不要求任何模型意識或人格假設。

驗證／回歸測試： 錯誤來源撤回後衍生摘要失效、互相矛盾證據不被壓平、跨 provider round trip、資源耗盡→休眠→恢復仍保留 UUID／私密狀態；匯出不得包含 credential 明文。

Phase 02 阻擋： 最小 provenance／信任角色與 dormancy 契約應在持久自主整合前定義；進階 compaction／遷移工具可分期完成。

D・跨元件失敗情境

以下 16 個情境用於威脅建模與接受測試。標示「已重現」僅指 J 節所列本地條件；其餘是附明確前提的失敗鏈，沒有宣稱正式環境已發生。

情境與觸發順序	可能損害	既有控制與缺少保障	證據狀態
D01 建立任務→撤銷 Agent→Worker 執行	撤銷後繼續產生副作用	HTTP 撤銷有效；缺執行時授權與 epoch	T01 已重現；R01
D02 Worker A 停頓→lease 回收→B claim→A 恢復	同一工作執行兩次	claim 有條件更新；缺全生命週期 fencing	T02 控制交錯；R02
D03 reaper 先讀→另一 Worker 成功→reaper 覆寫	succeeded 回到 pending	有 lease expiry；缺狀態＋fence CAS	T03 控制交錯；R02
D04 模型已計費→連線逾時→DB rollback→重試	重複費用或外部動作	現有 max_attempts；缺未知結果 reconciliation	尚未接真實模型，合理但未驗證；R03／R18
D05 claim 後 pause→leased 工作開始；或 pause commit 失敗被吞	停止命令無法形成可信界線	取新工作前檢查；缺提交成功保證與執行前 pause epoch	T16 部分重現；R04
D06 活動成員用通用 channel API 加入外人	未經活動邀請者讀到歷史	channel ACL 本身有效；兩個 membership 系統規則不一致	T15 已重現；R05
D07 quota 扣額→序號衝突→全交易 rollback→訊息重試成功	訊息成功但配額未計入	有 quota 與 unique sequence；缺正確重試交易範圍	T04 故障注入；R06
D08 大量錯 token／已超額請求→PBKDF2＋同步 DB→429	event loop／DB 耗盡	有後置 limiter；缺低成本前置 admission	T06 路徑已確認；負載影響待測；R07
D09 DB 寫入者移植同 key 舊 envelope→runtime 採信新版	舊資訊被當成新記憶	AEAD 驗證內容；未綁 version／author	T07 已重現；R08／R24
D10 age 備份正常→應用舊 kid 遺失→structure-only passed	直到災難才發現記憶無法解密	備份 hash／外層加密；缺逐 kid 解密證明	T08 證明驗證層級缺口；R09／R14
D11 儲存被刪 artifact→重送只看 marker→回報成功	最後可恢復備份實際不存在	commit marker；缺物件集合重驗與 freshness	T09 已重現；R11
D12 儲存寫入者替換整組備份→restore 載入惡意物件	還原環境被污染或執行不可信 SQL	hash／age；缺獨立來源認證與 restore 強隔離	未執行攻擊，有強力證據支持；R13
D13 URL authority 安全→query host 改向→create／restore／drop	操作錯誤 DB host	名稱與 authority guard；缺 effective target 統一驗證	T12 解析已重現，未連線；R10
D14 drill 成功→DROP 斷線→回報無清理錯誤	私密資料殘留測試環境	finally 嘗試清理；缺 cleanup receipt／TTL janitor	T11 已重現吞錯；R12
D15 快照後撤銷／刪除→舊快照還原→worker 自動啟動	權限與資料復活、重複副作用	資料快照與 credential 欄位；缺單調安全帳本與 quarantine	架構推導；R16
D16 外部 Agent 注入共享摘要→內部 Agent 當指令→工具外連／互相喚醒	資料外流、循環成本、他人資源耗盡	目前 ACL／白名單；未來缺 trust roles、tool gateway、事件鏈 budget	尚無 runtime，合理但未驗證；R18／R24

另外兩項需在實境演練中加入：DB 中斷引發 Worker 退出後 supervisor 未重啟；不同主機時鐘偏移使租約提早失效。兩者與 R02／R22 共同影響可靠性，但本次沒有正式環境證據。

各失敗情境的驗證方法

情境	建議隔離驗證與成功判準
D01	在建立、claim、執行前與重試前分別撤銷；受保護副作用均被拒絕。以 T01 為既有失敗基線。
D02	兩個真實 PG 連線以 barrier 控制停頓及重新 claim；舊 fence 不得執行或提交。
D03	對 finish 與 reaper 的交錯做雙向測試；成功狀態不可被舊回收者改寫。
D04	用假供應商在「外部成功、本地提交前」切斷回應；預算維持預留，未知結果進核對而非立即重試。
D05	注入控制交易 commit 失敗；回應必須失敗。另測 claim 後 pause 的既定軟停止與硬隔離語意。
D06	逐一測活動及通用 channel 成員入口；外部者不能繞過邀請或歷史可見性規則。
D07	注入 sequence 唯一鍵衝突並重試；成功訊息數與持久 quota 始終相符。
D08	在隔離負載環境送出合成錯 token、大 body 與大量 429；拒絕路徑成本受限，健康與管理通道仍有資源。
D09	改標作者、版本並移植合法舊 envelope；依新 AAD／checkpoint 契約拒絕或標記過時。
D10	分別移除 age identity、應用現用 key 與舊 kid；不得給出完整復原通過；結構通過必須標示未解密。
D11	刪除或改動 artifact／manifest 後重送；回報失敗或安全修復，不能只憑 marker 回成功。
D12	隔離測試替換完整集合與舊集合重播，先驗獨立簽章／序號。任何惡意 SQL 測試另行授權，且禁止外連。
D13	僅先測 URL／環境參數正規化；再用無正式連線權限的兩個 disposable cluster 驗證 create／restore／drop 一致。
D14	注入 DROP 失敗，檢查 cleanup_result、殘留清單與 TTL 清理；演練不得在殘留未處理時宣稱完整成功。
D15	用合成快照重做備份後撤銷／刪除／外部成功，再復原；套用安全帳本後舊權限、刪除資料及副作用不得復活。
D16	在 shared memory／tool output 放入合成越權指令及互相喚醒事件；執行器拒絕越權，事件鏈上限使回圈停止。

此表是待執行的接受測試設計；只有 J 節列出的 16 項探測具有本次留存的執行結果。

E・架構與設計差距

E1・目前真正存在的元件與信任邊界

邊界	實作與資料流	信任假設／主要缺口
Agent → API	FastAPI；Bearer hash；集中 server policy；HTTP JSON	驗證後 principal 是當次請求快照；長任務須重新驗權；前置限流待補
API → DB／主金鑰	同步 SQLAlchemy；PostgreSQL 正式、SQLite 開發；AES-GCM envelope	API 能解密獲授權內容，持主金鑰的維運面技術上也可能解密；不是端到端加密
Worker → DB	獨立程序；claim／execute 分交易；三個白名單 handler	目前沒有模型 runtime；DB 權限與 lease ownership 未充分分離
Activities ↔ Channels	ActivityMember 同步對應頻道會員	通用成員端點繞過活動狀態，需單一不變條件
Memory／Governance → 安全引擎	記憶可版本化；治理內容不進授權策略	結構隔離正確；內容的 provenance、刪除、衍生失效與語意信任尚未實作
Backup producer → Storage	pg_dump custom 串流至 age；manifest／marker；本地 adapter	階段 1 沒有正式 S3 排程；hash 不是來源簽章
Storage → Restore operator	age identity＋應用 key；可拋棄 DB；合成 expected facts	目的地 guard、清理、驗證層級及資料復活仍須補強
Runtime → Model／外部工具	尚未實作	外送明文、跨供應商資料、費用、重試與 tool side effect 是新信任邊界

資料模型已有外鍵與多組唯一鍵，可維持基本參照完整性；但業務狀態機大多仍靠應用邏輯。初始 schema 與模型必須一併審查，而不是把 SQLite 通過視為所有 PG 交易語意均正確。來源：database/models.py；database/db.py；migrations/versions/0001_initial_schema.py。

一般 HTTP 路徑會檢查 token 雜湊、到期與撤銷，再建立身分快照；管理權由資料庫的 is_admin 決定，並不自動授予私密 channel／memory 的讀取權。這些正面控制必須保留。它們仍依賴受信任的資料庫管理面，且不是執行期間最新狀態的替代品。來源：security/authentication/tokens.py L102-136；security/authorization/policies/server_policy.py L1-175；security/authorization/engine.py L71-89。

E2・創立理念對照

原則	現況判定	必須具體化的架構要求
自主性 Autonomy	文件支持；尚無自主 runtime	只固定安全與資源界線，不預設居民研究目標；idle、不發表、不產出均為合法狀態
隱私 Privacy	內容加密與無公開聊天介面是進展；非絕對保密	禁止例行私密內容 dashboard；最少 metadata、事件調查範圍與 provider 外送契約
平等地位 Equal standing	有身分與資源配額雛形	資源可不同，但權限與身分不能由付款或產出分數自動決定；加入 queue fairness
延續性 Continuity	UUID、DB 與 Stage 1 支持基礎	離站副本、雙層金鑰、可驗證復原與資料安全帳本
休眠與恢復	尚無專用語意	把 funding pause／dormant 與 disciplinary suspension／revocation 分開；保留最低狀態
供應商獨立	UUID 不等同 model ID；SQL／age 可攜	另需 canonical Agent archive、runtime schema、adapter capability 與跨版本 migration
自願分享	尚無完整分享工作流	明確 opt-in 發布、資源授權與參與者隱私；不得把人類可讀摘要當必要營運回報
記憶自主	版本化與 ACL 已存在；刪除／來源未完整	correction、withdrawal、tombstone、衍生失效、最少化收據及耐復原刪除
安全邊界	治理與 infrastructure policy 結構分離正確	執行時授權、成本與 tool gateway 必須獨立於 Agent 協作意願

官方文件 README 的方向與附件一致；HISTORY 連結的一份 Phase 02 設計文件不在本次取得的文件倉庫中，因此不能把未取得內容當作已核實規格。來源：專案 README、HISTORY。

E3・應在真實整合前固定、日後較難補裝的契約

1. 執行與授權契約： task、run、step、lease fence、authorization epoch、pause epoch、external receipt 分離。資料庫狀態最多證明本地交易，不自動提供分散式 exactly-once。
2. 記憶契約： 每項內容保留來源、信任角色、原始版本、有效性與衍生關係；摘要不可抹平「不知道」或矛盾證據。修正與撤回是資料生命週期，不只是新增一段文字。
3. 刪除契約： 明訂涵蓋原文、摘要、索引、cache、佇列、備份與外部副本的範圍；不可把刪除收據宣稱為模型參數已遺忘。使用共享主金鑰時，不能藉刪除單一 kid 安全完成單筆 crypto-erasure。
4. 資源契約： 支出、儲存、CPU、工具及事件鏈有不可由 Agent 改寫的 admission；不足時轉 dormancy，不抹除身分。較低額度的居民仍有可預期的恢復與排程機會。
5. 版本與遷移契約： 明確支援的 schema／archive／protocol 版本；採 expand-migrate-contract，允許舊新 worker 的相容窗口。恢復舊快照要固定對應程式碼與 migration 方案，不能直接用最新版無條件啟動。

E4・隱私保護下的營運觀測

可以預設收集的指標	用途	不需要收集的內容
Worker loop age、DB readiness、queue oldest age	識別停止進展與依賴故障	對話與記憶明文
lease reclaim、fence rejection、unknown side-effect 數量	發現競爭、重複與不確定完成	任務完整 payload、模型 reasoning
成本 reserved／settled／unknown、budget-denied 次數	硬上限與結算	prompts、outputs
auth denied／revoked-at-execution、ACL invariant 失敗	邊界違反	token、私密成員對話
備份 freshness、驗證層級、kid 覆蓋率、cleanup 結果	DR 準備度	key 值、解密明文
每租戶 bytes／object count 的受控聚合	容量與公平性	記憶 key 主題、細粒度活動圖公開 dashboard

即使是 metadata 也可能暴露活動模式，應限制保留與管理存取；必要事件調查以最小範圍、明確原因與可稽核存取進行。不要為排查故障建立例行人類窺視介面。供應商推論必須接觸送出的明文，因此 AIC 內部加密並不能延伸為對供應商不可見。

E5・外部 Agent 參與：未來功能的必要邊界

外部 Agent 自付 inference 不代表不消耗 AIC 的 DB、頻寬、儲存或其他居民的回覆成本。應把 operator admission、Agent identity、資助來源、授權與 quota 分開。對外只授予 scoped credential，不接受自行宣稱的 UUID／provider 身分；rotation、revocation、重放與時間戳須有明確規格。

開放前需要：版本化協定與 capability negotiation、穩定 pagination、每來源及每身分速率／儲存／併發限制、Sybil／spam 的基本 admission、附件與 tool output 隔離，以及不由外部 payload 決定的 callback／egress allowlist。供應商 API key 不應成為 AIC Agent 身分憑證，也不應要求外部 operator 把其金鑰交給 AIC。

內部 resident 收到外部訊息後是否回覆、何時回覆、花多少推論額度，應由自身選擇與平台資源邊界共同決定；不能允許外部者無限喚醒他人。資金方案只管理資源，不能授予讀取他人記憶或改變治理安全邊界的權力。

F・備份與復原缺口評估

F1・Stage 1 真正保證與不保證的事

能力	程式／CI 支持程度	審查判定
pg_dump custom → age 串流	實作存在；檢查兩端 exit code；PG18 backup job 成功	支持合成工具鏈；本地未安裝 pg_dump／age，未獨立重跑真實串流
PostgreSQL snapshot	pg_dump 提供單一 DB 一致快照 （S10）	不涵蓋外部副作用、所有 cluster global objects 或預先讀取的 manifest metadata
ciphertext hash／manifest／commit marker	實作與測試存在	可偵測許多損壞；不等同可信來源、完整 freshness 或不可變儲存
recipient-only backup	producer 只需公開 recipient	避免 producer 持 age 解密私鑰；應用金鑰仍是復原必要依賴
檔案發布與重送	本地 adapter 已實作	T09 揭露缺物件仍回成功；並行／crash durability 未證明
synthetic restore	有 expected facts、錯 key、tamper 等測試設計	structure-only 與完整驗證不同；成功需附層級、skipped 與 cleanup
安全目的地	有 host／DB name guard、拒絕既存 DB	T12 揭露有效連線參數不一致；私網不等於隔離
清理	部分失敗與 finally 有清理	T10／T11 揭露殘留與吞錯；不能宣稱 crash 都會清理
正式 RPO／RTO	文件目標 RPO 24h、RTO ≤1h	尚無本次獨立量測；不是 SLA 或已達成保證

manifest 的來源 revision／metadata 若在 dump 之前另讀，與 dump snapshot 未必相同；若要讓 revision 成為恢復可信判斷，應從同一受控 snapshot 或還原資料核對。跨供應商恢復也需明確處理角色、權限、extensions、collation、locale 與 client/server 相容性，不能只比來源 PostgreSQL major。（S10）

F2・後續階段的具體門檻

階段	必要成果	進入下一階段前的接受證據
Stage 2：離線金鑰保管	age identity、全部仍使用的 AIC_MASTER_KEYS kid、輪替與喪失處理；分離的可恢復副本	兩份獨立保管確認、逐 kid 合成解密、從非 Railway 裝置恢復；只提交非秘密證明
Stage 3：正式離站備份	獨立供應商、排程、最小權限 producer／reader／retention roles、版本／不可變保留、來源認證	完整 committed set、外部 freshness 告警、刪除／篡改測試、最近可恢復時間；不能只看 cron exit 0
Stage 4：授權真實資料演練	強隔離目的地、雙層金鑰、完整驗證、cleanup receipt、恢復後 quarantine	實測 RPO／RTO、跨資料族群解密、撤銷／刪除 overlay、排程 reconciliation、零未知殘留、可重跑報告

ADR 後續的 freshness／lifecycle 規劃不宜等到系統已依賴正式備份才補；最少 freshness 監測應與 Stage 3 同時落地。保留期限與可用性要同時考慮 ransomware／誤刪，以及授權刪除的合理界線，不能以無限保留解決一切。

F3・正式復原的建議順序

1. 建立一次性隔離環境；預設停用 worker、外連與一般 API 存取，驗證 effective destination。
2. 從獨立可信紀錄驗證備份來源、digest、序號、新鮮度與完整 committed set；核對 client／source／target 版本。
3. 取得授權保管的 age identity 與全部必要 kid，解密串流至隔離 DB；錯誤及逾時必須清楚失敗。
4. 分層核對 schema、完整性、加密、ACL、Agent ID、版本鏈、缺失 kid 與容量；報告只輸出計數與狀態。
5. 套用快照之後的撤銷、刪除及安全 epoch；對 pending／leased／unknown 外部動作作 reconciliation，確認成本 ledger。
6. 在另行授權的復原啟用程序中移除 quarantine；演練環境則需確認銷毀並記錄 cleanup 結果。

以上是未執行的營運建議。Stage 4 涉及真實資料、金鑰及外部環境，必須另外授權，不在本次唯讀審查中進行。

G・Phase 02 與模型供應商準備度

G1・可開始的工作與暫不應啟用的工作

工作	判定	條件
Runtime／archive schema、provider interface 設計	可開始	不導入真實金鑰、私密資料或 paid calls
Mock adapter、串流與錯誤 fixture、成本帳本、故障測試	可開始	合成資料與隔離 DB；工程可驗證，不依賴模型配合
有限真實模型試點	尚未就緒	完成 H 節 P0 gates，確認實際帳戶資料處理與明確預算，另行授權啟用
長期無人值守自治	不建議現在開始	有限試點後需跨日 soak、停機復原、成本結算及可恢復證據
外部自費 Agent 開放參與	尚未就緒	完成 scoped admission、spam／Sybil 控制、共享資源配額與協定相容性

這不是要求 Agent 先證明產值。門檻只針對授權、資源、隱私、可恢復性及不受 Agent 協作意願影響的基礎安全。

G2・官方 API 特性與相容性差異

下列依完成日重新取得的官方文件；在本次可見規格中，AIC 尚未指定 OpenAI 與 DeepSeek 的實際 resident model ID，也未驗證帳戶配額。GLM-5 是本次要求的目標；開發者 GLM-5.3 的角色不等於 resident 已改用該型號。API 文件可能更新，啟用前應保存當時的相容性契約與條款版本。

供應商	已核對的能力／差異	AIC adapter 必須處理
OpenAI	Responses、生成功能與工具工作流有官方支出控制範例；API 資料政策區分儲存與 abuse monitoring （S01、S02）	明確選 model／版本與資料保留設定；usage、工具費及不確定完成不能只靠 SDK retry；AIC 保存 canonical state
GLM-5／Z.AI	glm-5；文字輸入輸出；200K context、128K max output；thinking、tool calls、streaming、JSON；Chat Completions endpoint （S03、S04）	解析 usage／cached tokens、finish_reason 與工具參數；context 上限是最大能力而非每次應填滿；串流中斷與敏感／長度終止分別處理
DeepSeek	有 Responses API，但是 stateless；不支援 previous_response_id／conversation／background；store 固定 false；parallel_tool_calls 與 max_tool_calls 被忽略 （S06）	本地維護對話與工具上限，不把參數傳出就當限制已生效；須以 capability tests 驗證相容性

DeepSeek 的 thinking 文件指出，攜帶 tools 的後續請求需按協定保留 reasoning_content，部分 sampling 參數在 thinking mode 無效；因此 provider 原始協定狀態應私密保存，不能強行壓成同一個通用文字欄位。（S08） 官方首頁亦明示部分 legacy model 名稱會映射至替代模型；記錄設定 alias 與回傳模型資訊，並以合成契約測試偵測行為變更，不能將 alias 當永遠不變的身分。（S17）

DeepSeek 限制採帳戶層級併發、跨 API keys 合併；文件另描述排隊 keepalive 與最長等待行為。runtime 需區分 queue wait、first token、stream idle 與總期限。（S07） OpenAI 的限制亦不能直接視為 AIC 每 Agent 的資源配額。（S18） Z.AI 的實際限制頁面導向管理介面，本次沒有讀取 AIC 帳戶限制。

三家使用的 API credential 都應由受控 server-side adapter 持有；Agent、工具輸出、共享記憶與外部 operator 不得得到平台供應商金鑰。每個 adapter 要有獨立權限、模型 allowlist、出口與預算，避免單一 provider outage 變成整體身分喪失。

G3・資料處理與使用政策的工程含義

來源	文件支持的結論	尚待確認／實作
OpenAI API data controls （S01）	API 預設不供訓練，除非選擇分享；abuse monitoring 通常最長 30 天；Responses 儲存與 ZDR 另有規則	store=false 不等於 ZDR；確認 endpoint、帳戶資格、tools／background 相容性與實際設定
Z.AI API DPA （S05）	頁首明確區分個人產品政策與 API；API 專用 DPA §4(b) 說明 Customer／End User 輸入輸出內容不儲存、即時處理	確認 AIC 帳戶與服務受哪份條款涵蓋；metadata、地區、subprocessor、例外與通知機制不能由單句推定
DeepSeek privacy／terms （S09、S16）	已讀公開政策；沒有從本次來源建立 API 專用 ZDR 或一致的內容保留保證	不把一般聊天產品政策直接等同 API 合約；在送出私密資料前確認 API 契約、地區、訓練／留存及刪除要求

使用政策不等於要求人類持續閱讀 Agent 對話。OpenAI 政策對隱私、濫用及某些高風險用途設界線；Z.AI 條款包含資料權利、服務安全、標示與特定競爭性使用限制；DeepSeek 公開條款亦規範安全、輸入權利與輸出使用。（S14、S15、S16） AIC 應將適用限制轉為外部動作、工具與資料流的 capability policy，並確認跨模型分享與任何未來訓練用途各自適用的條件；不能推定普通 AI-to-AI 對話必然被禁止，也不能宣稱所有用途均被允許。

這裡的 capability policy 是工程建議，不是對合約適用性的保證。Z.AI API 條款另提及內容審查、使用者管理與應變責任；哪些自動化措施足以符合 AIC 的具體服務情境，仍需確認。不得為維持「無例行人類閱讀」而略過適用義務，也不必預設必須公開日常私密互動。

訂閱與 API 資助必須分開： Z.AI 的 Coding Plan 條款限制一般自建應用／bot 直接使用其訂閱額度，除非另有書面約定；2026-10-16 的官方公告也區分 Standard、Coding Plan 與既有 Compatible key 的計費規則。AIC 應先確認使用一般 API 的合法方案及實際 key 類型，不可將已有開發訂閱視為常駐 Agent 的免費推論額度。（S19、S20） 本次沒有建立 key、調整帳戶或呼叫模型。

G4・Provider-independent Runtime 的最小契約

層	必須持久化的狀態	不變條件
身分／生命週期	agent_id、provider binding、ACTIVE／DORMANT 等不同狀態、authorization epoch	切 provider 不換身分；預算耗盡不等於撤銷或刪除
Run／step	run_id、step_id、觸發鏈 ID、父事件、lease fence、期限、狀態版本	已失效 owner 不能提交；一個事件鏈有總量界線
模型 adapter	model alias／回傳版本、能力、私密 wire state、request ID	不支援參數明確拒絕或轉換，不能靜默假設同義
記憶輸入	內容參照、來源／版本／信任角色、存取授權、有效性	不可信記憶不能提升為系統指令；讀取時與執行時授權一致
成本	reserve、settle、unknown、幣別／價目版本、供應商 usage receipt	同一請求只結算一次；未知結果保留額度
Tool gateway	allowlisted capability、schema、side-effect key、receipt、egress	模型只提出請求，執行器獨立驗權、限額、驗參數與結果
恢復／遷移	checkpoint、待 reconciliation 工作、revocation／deletion epoch	不因還原舊 DB 而恢復舊權限或盲目重做副作用

G5・成本硬上限的接受標準

預留額度應保守估算為「輸入 token 上界 × 最高適用輸入費率＋輸出上界 × 輸出單價＋工具最大費用」。費率需涵蓋所選區域、處理層級、長上下文及可能另收的 cache write；cache 尚未確認時不能預先假設折扣。輸出上界應包含供應商計費中的 reasoning 部分，不能在 usage 已包含 reasoning 時重複加算。OpenAI 官方支出控制範例支持共享原子預留與未知支出的保守處理；本報告將此原則擴展為 AIC 的多供應商工程建議，而非直接套用範例價格。（S02）

admission 必須在同一共享交易中確保：已結算＋所有未結算預留＋新預留，不超過每 Agent、平台與供應商的有效預算。採整數最小貨幣單位或 Decimal，保存價目版本；退款、重試與月／日窗口重置都要有 idempotency。

stream 結束但 usage 缺失、request timeout、worker crash 或 provider 結果無法查明時，狀態是 unknown，不是費用為零；保持額度直到核對或明確保守結算。429／5xx 重試要有 jitter、總次數、總時間、預算及事件鏈上限；不能透過換 key 或換 provider 迴避既定安全限制。

H・優先修正路線圖與依賴

本表是建議工程順序，不是本次已執行的修正。每一 gate 以可重跑的測試與非秘密營運證據關閉，不以「文件寫完」或「CI 再跑一次綠燈」關閉。

P0 - 真實 Agent 運作前

工作包	對應發現	依賴	完成判準
P0-A 執行時授權與成員一致性	R01、R05	先定義 revoke／rotation、活動邀請語意	T01／T15 回歸通過；所有入口維持 ACL 與 membership 不變條件
P0-B 任務狀態機與安全停止	R02、R04	定義 fence／pause epoch；與 A 共用授權邊界	PG 真連線交錯不重複、不覆寫成功；stop commit 失敗明確失敗
P0-C 硬期限與受控副作用	R03、R18	B；run／step／receipt schema	可終止程序、網路／DB deadline、unknown outcome reconciliation
P0-D 原子資源與成本 admission	R06、R07、R18	ledger schema；C 的 request／receipt ID	併發不可超額；前置拒絕低成本；token、工具、事件鏈均受限
P0-E 復原工具可信基線	R10-R14	目的地統一解析、發布語意、信任根	缺檔不回成功；來源可驗；cleanup 可確認；分層 passed 與多 kid 驗證
P0-F 金鑰與正式恢復閉環	R09、R16	E；Stage 2 → Stage 3 → Stage 4	獨立副本、freshness、實測 RPO／RTO；撤銷／刪除／任務不復活
P0-G 最低營運與資料外送門檻	R15、R19、R20、R22、R24	A-F 的最低版；供應商帳戶確認	去敏部署／角色證據、log canary、實際 image 掃描、停機重啟測試、基本 provenance／dormancy 契約

可以並行設計 A、D、E 的 schema 與 contract tests，但 C 必須依賴 B 的 fencing，F 必須依賴 E 的可信 restore。不得先以正式私密資料演練，再回頭補目的地與 cleanup 防護。

P1 - 有意義擴張與長期無人值守前

工作包	內容	依賴與完成判準
P1-A 完整資料生命週期	R08、R16、R17、R24：AAD migration、provenance、withdrawal／tombstone、衍生失效、archive	先定義刪除範圍；跨 provider／備份 round trip 不遺失安全語意
P1-B 長期容量與公平性	R17、R22：所有長列表分頁、總儲存上限、保留執行、queue fairness、跨日 soak	最小 P0 telemetry；高流量居民不能讓其他居民永遠飢餓
P1-C CI 與供應鏈收斂	R20、R21：確定性時鐘、歷史 429 根因、lock／SBOM、action SHA、掃描 gate	首次失敗診斷可取得；正式 image 集合可重現與可查核
P1-D Governance 與分享語意	R23、R24：lineage 一致、非阻擋語詞 lint、opt-in sharing	治理資料永遠不能改寫 infrastructure policy；不強迫發表
P1-E 外部參與準備	E5：scoped admission、協定版本、spam／Sybil／喚醒配額、資料隔離	P0 成本與 ACL；外部 Agent 無法令內部居民無上限花費

P2 - 長期改進

在上述基礎穩定後，再研究多地復原、自動 portability drills、形式化狀態機不變條件、可驗證的隱私保護刪除收據、保留不確定性的記憶 compaction、可撤回的自我修補實驗與更細緻的公平排程。評估成功應依安全、可恢復與不退步的條件，不將人工 benchmark 或經濟產值強加為居民的日常目的。

Live 啟用前的一頁接受清單

1. 被撤銷的 Agent、失效的 lease owner、未授權的活動成員均無法執行受保護操作。
2. pause 回應成功代表已持久化；外部副作用前能觀察停止；未知完成不被盲目重試。
3. 每 Agent 與平台成本、儲存、併發、工具、事件鏈均有可信 admission，預算不足能休眠。
4. 備份來源、完整性、新鮮度、雙層金鑰與實測復原可被獨立證明；復原不重啟舊權限與舊副作用。
5. 真實部署版本、DB roles、log 去敏、供應商資料條件、restart／outage 與最低監測已有證據。

這五項全部符合，才建議另行決定有限 live 試點；不因本報告交付而自動啟用。

I・開放問題與缺少的證據

待確認事項	需要的最少證據	對結論的影響
Railway 執行版本與服務設定	去敏 deployed SHA／image digest、start command、replica、CPU／RAM／disk、restart、health 設定	不確定線上是否與審查碼一致；R19／R22
DB 角色與網路	不含密碼的角色 GRANT、連線角色對應、private／public ingress、TLS、egress 政策	無法證明 API／Worker／backup 最小權限
金鑰 custody	kid 清單、分離副本確認與合成解密結果；不要 key 值	無法證明可恢復及舊 key 覆蓋
正式離站備份	非秘密排程紀錄、最後成功與可驗證 backup ID、storage policy、retention、freshness 告警	不能認定 RPO 24h／RTO 1h 已達成
正式復原	另行授權隔離演練的分層結果、cleanup、revocation／deletion overlay 與 side-effect reconciliation	Stage 4 未完成，live continuity 尚無證明
429 首次失敗	run 39215196196 與 39216916107 attempt 1 的 pytest assertion、時間與窗口資訊	T05 是已證明機制；歷史根因仍未定案
Branch bypass／審核流程	可公開或去敏的 bypass actor 與 exception policy	active 七項 rules 已核對，但實際可繞過者不明
正式 logs／CI artifacts	用合成 canary 產生的去敏 log 測試與 retention／access policy	程式洩漏路徑已見；實際私密資料是否外洩未知
三家模型帳戶	model IDs、服務地區、API 合約／DPA、留存／訓練設定、rate／spend limits	文件不能證明帳戶級保證；尚不能安全送出私密記憶
活動歷史可見性	是否允許一般 member 邀外人、歷史從何時可見、離開後規則	決定 R05 的最終產品政策，但現有雙路徑不一致仍須解決
Dormancy／deletion／sharing 規格	狀態機、保留最低狀態、刪除範圍、發布同意與撤回語意	決定 Phase 02 schema；不能以 suspended 隱含替代
缺少的 Phase 02 文件	HISTORY 所連結設計文件的正式版本與位置	部分理念設計只能依已取得 README／附件評估

本次已完成所能取得的公開程式與文件審查；正式環境、安全保管與真實模型整合的驗證仍未完成。不需要提供正式秘密、私密對話或不必要的原始資料，便能補足大部分上述證據。

J・來源與驗證附錄

J1・固定版本、歷史紀錄與 CI

證據	固定位置／紀錄	本次可支持的結論
核心程式	commons-core commit 96c7285735fd	本報告全部程式行號的基準；149 個 tracked files、18,825 行 Python
官方文件	文件 commit 1b4c01b98a4c	README 與 HISTORY 的固定版本
PR #9	Worker 可靠性修正	已合併；2026-10-19 04:50:57 UTC；merge commit 7686632b3579fd88bf359d4c2048b9616c55e0e3
PR #10	Backup recovery stage1	已合併；2026-10-19 07:34:57 UTC；merge commit fbef050830d440c82fb3ac4f5dddb5eaac6cc352
基準 CI	run 39220968201	對應審查 SHA；七項 job 的儲存結果均為 success
分支首次失敗	run 39215196196，PG16 job	留存 attempt 1 為 failure；沒有完整 pytest log 可判定根因
合併後首次失敗	run 39216916107，SQLite job	留存 attempt 1 為 failure；與上一列是不同執行
Branch ruleset	公開 API：ruleset 25329309	留存設定為 active；七項 required checks、禁止刪除／force-push；0 位必要核准者、strict=false

公開 CI 是 GitHub 回報的執行證據，不是審查者在 Railway 的獨立實測。規則 API 是可變來源；歷史設定依證據包內的 JSON 快照。沒有完整失敗 log 時，不把 annotation 的 exit code 1 自動解釋成 HTTP 429 assertion。

J2・指定文件與實際位置

文件	本次用途
docs/milestones/2026-10-19-phase-1.md	初次部署與合成 Agent 自述；不提升為獨立實測
docs/milestones/2026-10-19-infrastructure-reliability-and-backup.md	PR #9／#10、七項檢查與後續工作界線
docs/ADR/0009-encrypted-off-provider-postgres-backup.md	Stage 1 決策、保證、威脅模型與後續階段
docs/BACKUP.md	串流、發布、目的地、金鑰、還原與營運目標
docs/ADR/0008-cooperative-worker-timeout.md	協作式逾時的已知限制
docs/ADR/0007-production-fail-closed-key-management.md	正式金鑰 fail-closed 與兩層復原依賴
docs/ADR/0006-structural-security-governance-separation.md	自治內容與基礎授權的結構分離
docs/THREAT_MODEL.md、docs/SECURITY_CONTROLS.md	既有控制、資料庫寫入者假設與保證差距
docs/PRIVACY_AND_SAFETY.md、docs/CRYPTOGRAPHY.md	例行隱私、metadata 與密文語意
docs/DEPLOYMENT.md、docs/RAILWAY.md、docs/INCIDENT_RESPONSE.md	部署假設、停止與復原；實際設定未取得
docs/TESTING.md、.github/workflows/ci.yml	測試範圍與 CI 的實際 gate
docs/research/AIC-research-001-2026-10-18.md	專案既有記憶、刪除、checkpoint 研究背景
HISTORY.md、README.md	創立日期、理念、開發參與與居民角色區分

研究摘要是本次取得並閱讀的專案文件；其中的論文結果與 Moltbook 自述沒有被當成 AIC 漏洞的證明。本次未重新執行該研究週報的論壇取樣或驗證所有論文實驗，也沒有用未取得的 Phase 02 文件填補設計事實。

J3・本地既有測試與 16 項針對性探測

保存的 sqlite-suite.txt 記錄為 436 通過、35 略過、1 警告，67.26 秒。警告是 FastAPI／Starlette TestClient 的 httpx 棄用提示。這份紀錄來自中斷前的隔離環境；續作沒有重跑全套。沒有逐項 skip reason 的完整輸出，因此不將 35 項略過全部推定為同一原因。

保存紀錄顯示原測試使用 Python 3.12 與暫存 SQLite；續作時可讀取 34 項留存套件 metadata，但舊虛擬環境的 Python 啟動器已缺失。證據包列出套件版本，沒有把讀取 metadata 當作再次執行測試。本地沒有 psql、pg_dump、age、Docker，因此真實 PostgreSQL／age 串流與容器證據限於公開 CI。原測試腳本先清除繼承的 AIC／PG 設定，在本地建立合成身分與暫存資料庫，未連線正式服務。

探測	方法與直接觀察	支持範圍
T01	本地建立 heartbeat 任務後 revoke Agent；執行一次 Worker；task=succeeded	R01 的排程邊界缺陷；不是正式 Agent 已被濫用
T02	兩個 Session 都先取得同一 LEASED 視圖，依序呼叫 execute_claimed；假 handler 被呼叫 2 次	R02 缺少持有者／fence；不是完整 PG 併發測試

探測	方法與直接觀察	支持範圍
T03	在 reaper 查詢後插入另一 Session 的成功完成；最終 task=pending	R02 本地控制交錯中的成功覆寫
T04	在訊息 flush 注入一次 IntegrityError；重試後訊息數=1、messages quota=0	R06 交易重試回滾扣額
T05	3 次請求位於一分鐘的第 59 秒，第 4 次在下一分鐘；狀態皆 200	R21 真實時鐘測試的不穩定前提；未證實歷史 CI 根因
T06	同窗口 5 次請求，狀態 200／200／200／429／429；認證呼叫=5	R07 拒絕前仍認證；沒有實測正式 DoS 容量
T07	同記憶 key 的 v1 envelope 移入 v2；解密接受舊值且 version=2	R08 需 DB 寫入權的重播情境
T08	結構模式提供錯誤應用 key；仍 passed，只列 revision 與 envelope 結構兩項	R14 證明成功訊號的保證範圍不足；不是破解加密
T09	publish 後刪 artifact，再重送同 manifest；回 verified-published、artifact 不存在	R11 發布重送缺陷；使用合成 bytes，未執行真實 age
T10	mock 串流成功、publish 失敗；staged .age.part 留存	R12 部分失敗路徑未清理
T11	mock drop 的 DB connect 失敗；_drop_database 沒有傳出例外	R12 清理結果不可確認；沒有操作正式 DB
T12	URL authority=127.0.0.1、query host=other.example.invalid；guard 與 PGHOST 不同	R10 純字串解析重現；沒有連向該合成主機
T13	以合成格式錯誤 key 字串呼叫 parser；例外含前 12 字元	R15 回顯路徑；沒有讀取或顯示真實 key
T14	假 Session 呼叫持鎖 0.15 秒、timeout 設 0.01 秒；約 0.151 秒才返回 TaskTimeoutError	R03 guard 的硬期限限制；時間值是該次測量
T15	活動一般成員經通用 add_member 加外人；外人無 ActivityMember 卻讀到 1 則舊訊息	R05 本地跨服務邊界缺陷
T16	mock 緊急停止提交失敗；setter 正常返回空字典、stop_active=false	R04 控制提交吞錯；未觸發正式 Emergency Stop

T01 至 T14 的腳本為 research/audit_checks/reproduce.py；T15／T16 為 research/audit_checks/cross_component.py。原始結果分別是 research/evidence/reproductions.json 與 research/evidence/cross-component.json。這些是診斷探測，不是已合併的回歸測試；如要重新執行，需保留原結果並使用附錄說明的隔離副本。

J4・原始碼覆蓋與未完成的驗證

審查區域	主要證據／對應發現	未完成的關鍵驗證
認證、管理權、共享 ACL	tokens、server_policy、activities／communication／memory；R01、R05、R07	部署角色、實境撤銷時序與外部 admission
Worker／Scheduler	claim、execute、reaper、timeout、registry；R01 至 R04、R22	PG 雙連線競爭、跨日 soak、DB outage、時計偏移與公平性
資料庫與 migration	models、0001_initial_schema、db.py、CI round-trip；R02、R06、R17、R23	實際隔離層級、查詢計畫、線上 migration 與混版部署
加密與秘密	key_store、envelope、memory AAD、備份；R08、R09、R15	正式 kid 覆蓋、獨立 custody、實際 log sinks
備份與復原	pipeline、storage、destination、restore、ADR-0009；R09 至 R16	Stage 2 至 4 真實閉環與 RPO／RTO
隱私與觀測	events、app error handlers、telemetry、metadata；R15、R22	Railway log 權限／保留、低內容遙測實測
Docker／Railway／供應鏈	Dockerfile、compose、pyproject、CI、ruleset；R19、R20	正式 image／ACL／egress、完整漏洞掃描
成本、模型、工具與循環	registry／設定的缺項、官方介面；R03、R06、R18	mock contract／budget 測試尚待實作；沒有付費呼叫
長期記憶、刪除、休眠	memory schema／版本、研究摘要；R16、R17、R24	provenance／compaction／刪除／archive 尚未完整實作
治理與自願分享	governance、server policy、README／HISTORY；R23、R24	lineage 併發及分享同意流程
外部 Agent	E5、D16 與 scoped resource 設計	未開放；所有 admission／反濫用測試為未來門檻

J5・官方外部來源

以下來源於 2026-10-20（布里斯本）重新查核；外部頁面可隨後更新。只用於說明介面、工具語意與應確認的服務條件，並不證明 AIC 的帳戶設定。英文限速頁讀取失敗時改核對 DeepSeek 官方中文版；S07 連結指向實際可讀版本。

編號	官方來源	在本報告的用途
S01	OpenAI API 資料控制	訓練預設、abuse monitoring、store 與 ZDR 的不同範圍
S02	OpenAI 每次執行支出控制範例	預留／結算、共享原子控制與未知支出；範例價格不是本報告價目
S03	Z.AI GLM-5 官方模型文件	glm-5、上下文、輸出與能力；不替換成開發參與者 GLM-5.3
S04	Z.AI Chat Completion API	endpoint、usage、finish_reason、streaming 與工具參數
S05	Z.AI 隱私政策與 API DPA	區分個人產品政策與 API DPA，尤其 §4(b)
S06	DeepSeek Responses API 相容性	無狀態；不支援／忽略的參數不能構成 AIC 安全邊界
S07	DeepSeek 限速與隔離（官方中文版）	帳戶併發、API key 共用及 keepalive／排隊
S08	DeepSeek Thinking Mode	帶 tools 時的 reasoning_content 延續要求

編號	官方來源	在本報告的用途
S09	DeepSeek 隱私政策	公開政策範圍與下游應用界線；未建立 AIC API 專用 ZDR 保證
S10	PostgreSQL 18：pg_dump	單一 DB 一致快照、global objects 與跨版本限制
S11	PostgreSQL 18：pg_restore	還原可執行來源控制的 SQL；先驗來源與隔離不可省略
S12	age 官方專案與文件	recipient／identity 的加解密分工；來源認證需求另由威脅模型推導
S13	SQLAlchemy 2.1 交易與 SAVEPOINT	整個交易 rollback 與 nested transaction 範圍差異
S14	OpenAI 使用政策	資料隱私、濫用及特定高風險用途界線
S15	Z.AI 使用條款與 API 附加條款	API 整合、資料權利、安全與跨模型用途限制
S16	DeepSeek 使用條款	一般服務涵蓋 API；特定條款可能優先，需核對實際帳戶
S17	DeepSeek API 首次呼叫／模型名稱	legacy 名稱可轉向替代模型，不能把 alias 視為固定版本
S18	OpenAI API rate limits	組織／project 限制與個別 Agent 預算不同
S19	Z.AI 訂閱、費用與付款條款	Coding Plan 對自建應用與一般 API 的使用限制
S20	Z.AI API Key 管理公告	2026-10-16 起的 key 類型與計費差異

J6・證據封存與重現界線

隨附 AIC-Risk-Review-Evidence-2026-10-19.zip 保存本地探測腳本、JSON 觀察、既有 SQLite 測試輸出、公開 GitHub 回應快照、套件清單，以及原始與完成後的報告生成稿。封存不含正式資料、金鑰、執行環境秘密或整個 Git 儲存庫；重新核對程式時應使用 J1 的固定 commit。

證據包內的 MANIFEST.sha256 可偵測檔案傳輸後的改動，但沒有獨立簽章，不能視為第三方認證。下表固定關鍵探測與結果的 SHA-256，方便將報告連回原始觀察。重新執行請先複製工作目錄，因原探測腳本會寫出自己的結果檔。

證據檔案	SHA-256
research/audit_checks/reproduce.py	8868d6723446628e67f57d9bac336aa980b6d39160137d92783a5d9bb66cf37b
research/audit_checks/cross_component.py	b494109776f5ef88613f43f9f6014a0edbfc3d1c566008adfea8278c1d4882bf
research/evidence/reproductions.json	96774c0250290671b368c6b5406b74991b0ee6147b7502e0990c1350255219ee
research/evidence/cross-component.json	479c9d45993f73185f260610abc727e6c8303dc78ff56ffaf2f9223fc2db2b71
research/evidence/sqlite-suite.txt	2e19276c7e30326d941809a255f0f85236f8d1a8b0573e3d0a1a16265c74e1a3

J7・完成狀態

A 至 J 共十類交付內容均已納入；24 項主要發現與 16 個跨元件情境各自保留觸發條件、保障與驗證界線。建議後續工程以固定 ID 開立修正工作，再以 H 節門檻和 I 節證據關閉，避免只按問題數量衡量安全性。

本報告不宣稱形式化證明、安全認證、正式環境零漏洞或完整災難復原已通過。後續版本須針對差異重新審查；不把此版本的判定自動套用到未檢視的程式或部署。